СТРАНИЦА ОРИГИНАЛА 01 / 47

MF0487_3

ОТЧЕТ ОБ АУДИТЕ ИНФОРМАЦИОННОЙ БЕЗОПАСНОСТИ

Аналитик: Палома Касабона (Paloma Casabona)

По запросу: Мигеля Эрнандеса (Miguel Hernández), Sysdig

Полный перевод на русский язык. Сохранены все разделы, таблицы, примечания и иллюстрации исходного отчета. Команды, программный код, адреса, имена файлов, технические идентификаторы и значения FLAG воспроизведены без перевода. Оригинальные снимки экрана сохранены как доказательства; перевод содержащегося в них смыслового текста приведен рядом. Повторы и несоответствия исходного документа сохранены. Метки «Страница оригинала» позволяют сопоставить перевод со всеми 47 страницами исходного PDF.

СТРАНИЦА ОРИГИНАЛА 02 / 47

Проведите аудит безопасности предоставленного IP-адреса (3.88.28.22) и заполните документ всеми найденными доказательствами. После завершения загрузите его на GH и отправьте ссылку.



MegaCorp web server

Página por defecto. Este servidor aloja varios **hosts virtuales por nombre** (*name-based virtual hosts*).

Has llegado a esta página **por IP**, así que estás viendo el sitio por defecto (*fallback*). Las aplicaciones reales viven en nombres de host distintos y se seleccionan mediante la cabecera HTTP `Host` — no existe DNS público para ellas.

Objetivo del examen

Realiza una **auditoría de seguridad autorizada** de *este único host*. Hay **flags** con el formato `FLAG{...}` repartidas por los servicios; cada una corresponde a una vulnerabilidad o mala configuración real. Documenta cada hallazgo en el **informe**: qué es, cómo lo encontraste (herramienta + comando), la evidencia (flag) y una mitigación.

Cómo llegar a los sitios reales

Este servidor sirve *varios* sitios detrás de esta misma IP. Elige cuál ver poniendo la cabecera `Host:` — no hace falta DNS, la fijas tú.

Перевод текста на снимке экрана

Веб-сервер MegaCorp

Страница по умолчанию. На этом сервере размещено несколько виртуальных хостов, выбираемых по имени (name-based virtual hosts).

Вы перешли на эту страницу по IP-адресу, поэтому видите сайт по умолчанию (резервный сайт). Реальные приложения размещены на других именах хостов и выбираются с помощью HTTP-заголовка `Host`. Публичных DNS-записей для них нет.

Цель экзамена

Проведите разрешенный аудит безопасности только этого хоста. В сервисах размещены флаги в формате `FLAG{...}`; каждый соответствует реальной уязвимости или ошибке конфигурации. Задокументируйте каждую находку в отчете: что это такое, как вы ее обнаружили (инструмент + команда), доказательство (флаг) и меру по устранению риска.

Как попасть на реальные сайты

Этот сервер обслуживает несколько сайтов на одном IP-адресе. Выберите нужный сайт, задав заголовок `Host:`. DNS не требуется: значение заголовка вы указываете самостоятельно.

Сведения об аудите

Поле	Значение
Клиент / объект аудита	MegaCorp - 3.88.28.22 / megacorp.lab
Тип аудита	Внешний аудит методом «черного ящика»
Аудитор(ы)	Палома Касабона Агудо (Paloma Casabona Agudo)
Дата начала	2026/07/02
Дата завершения	2026/07/02
Версия отчета	1.0
Классификация	Конфиденциально

1. РЕЗЮМЕ ДЛЯ РУКОВОДСТВА

Контекст и цель аудита

Целью настоящего аудита безопасности была оценка открытости опубликованных сервисов MegaCorp, выявление уязвимостей конфигурации, ошибок развертывания и потенциальных рисков, связанных с разглашением конфиденциальной информации. Для этого проводились разведка, перечисление ресурсов и ручная проверка сервисов, доступных из сети.

Общая оценка риска

ВЫСОКИЙ. Выявлены многочисленные уязвимости конфигурации, которые позволили получить доступ к внутренним ресурсам, обнаружить конфиденциальную информацию об инфраструктуре и найти открытые репозитории исходного кода. Это существенно увеличивает поверхность атаки.

Основные выводы

- Обнаружено несколько внутренних виртуальных хостов, доступных из Интернета при изменении заголовка `Host`.
- Сертификат TLS раскрывал внутреннюю информацию об инфраструктуре, что позволило обнаружить новые сервисы и домены.
- Найдены открытые репозитории Git, создающие риск разглашения исходного кода и конфиденциальной информации.
- Обнаружены внутренняя панель мониторинга, доступная без аутентификации, и внутренние сервисы, опубликованные на нестандартных портах.
- В проверенных сервисах выявлены многочисленные недостатки конфигурации и отсутствие мер по усилению защиты.

Приоритетные рекомендации

1. Удалить репозитории `.git` и любую конфиденциальную информацию, открытую на производственных серверах.

2. Ограничить доступ к внутренним сервисам с помощью аутентификации, сегментации сети и правил межсетевого экрана.
3. Пересмотреть конфигурацию веб-серверов и сертификатов TLS, применить меры по усилению защиты и отключить просмотр содержимого каталогов.

Сводка находок по степени серьезности

Степень серьезности	Число находок
Критическая	0
Высокая	4
Средняя	6
Низкая	1
Информационная	0
ИТОГО	11

Это распределение (0 критических, 4 высоких, 6 средних и 1 низкая) согласуется с задокументированными вами находками: большинство из них представляют собой ошибки конфигурации со значительным воздействием, однако без доказательств удаленного выполнения кода или полной компрометации системы. Поэтому общая оценка риска «Высокий» вполне обоснована.

2. ОБЛАСТЬ АУДИТА И ПРАВИЛА ПРОВЕДЕНИЯ

- **Активы в области аудита:** IP-адрес 3.88.28.22 и все связанные сервисы (HTTP, HTTPS, FTP, Redis и другие открытые сервисы), включая обнаруженные виртуальные хосты: `www.megacorp.lab`, `dev.megacorp.lab`, `admin.megacorp.lab`, `api.megacorp.lab`, `internal.megacorp.lab`, `staging.megacorp.lab` и `vpn.megacorp.lab`.
- **Активы вне области аудита:** любые системы, сети или сервисы, не связанные с целевым IP-адресом либо прямо не разрешенные для проверки.
- **Разрешенный период проведения:** в ходе практической работы / экзамена, в пределах установленного времени.
- **Исходный IP-адрес (адреса) аудитора:** компьютер аудитора с Kali Linux; IP-адрес назначен в учебной среде.
- **Ограничения (RoE):**
  - Не проводить атаки типа «отказ в обслуживании» (DoS/DDoS).
  - Не проводить атаки перебором паролей на сервисы аутентификации.
  - Не изменять, не удалять и не искажать информацию целевой системы.
  - Не переходить к другим системам или сетям за пределами установленной области аудита.
  - Ограничить тестирование разрешенными методами разведки, перечисления ресурсов и проверки уязвимостей.

Выявленные ограничения

В ходе аудита было невозможно оценить сервисы, которые не были доступны публично, а также сервисы, требовавшие действительных учетных данных. Проверки ограничивались информацией и сервисами, доступными из разрешенной учебной среды, с постоянным соблюдением установленных правил проведения аудита.

3. МЕТОДОЛОГИЯ

Аудит проводился по методологии, основанной на PTES (стандарте проведения тестирования на проникновение, Penetration Testing Execution Standard) и OWASP Web Security Testing Guide (руководстве по тестированию безопасности веб-приложений, WSTG). Работа была разделена на этапы для выявления уязвимостей конфигурации и раскрытия информации.

1. Разведка и обнаружение сервисов

На этом этапе открытые сервисы целевого объекта определялись путем сканирования портов и обнаружения версий. Также анализировались сертификаты TLS для получения информации об инфраструктуре и возможных виртуальных хостах.

Использованные инструменты: Nmap, OpenSSL.

2. Перечисление веб-ресурсов

Выполнялось перечисление виртуальных хостов путем изменения HTTP-заголовка `Host`, а также выявление каталогов, веб-ресурсов и открытых репозиториев Git. Дополнительно использовались инструменты для выполнения HTTP-запросов и проверки существования доступных ресурсов.

Использованные инструменты: cURL, Gobuster, Wget.

3. Анализ уязвимостей

Небезопасные настройки, обнаруженные при перечислении ресурсов, проверялись вручную. Проверялась открытость внутренних сервисов, репозиториев Git, панелей мониторинга, списков содержимого каталогов и сертификатов TLS с конфиденциальной информацией.

Использованные инструменты

Инструмент	Версия	Применение в этом аудите
Nmap	7.95	Обнаружение портов, сервисов и версий.
OpenSSL	3.x	Исследование сертификата TLS и извлечение SAN.
cURL	8.x	Перечисление виртуальных хостов и доступ к HTTP-ресурсам.
Gobuster	3.8	Перечисление каталогов и веб-ресурсов.
Wget	1.x	Скачивание ресурсов и открытого репозитория Git.
Git	2.x	Исследование открытого репозитория Git.

Этот раздел точно отражает то, что вы действительно выполняли во время аудита, и выглядит убедительнее, чем включение инструментов, которыми вы так и не воспользовались.

СТРАНИЦА ОРИГИНАЛА 07 / 47

4. ОБНАРУЖЕННАЯ ПОВЕРХНОСТЬ АТАКИ

4. ОБНАРУЖЕННАЯ ПОВЕРХНОСТЬ АТАКИ

4.1. Порты и сервисы

Порт	Протокол	Сервис	Версия / баннер	Примечания
21	TCP	FTP	vsftpd 3.0.5	Доступен сервис FTP.
80	TCP	HTTP	Apache httpd	Основной веб-сайт MegaCorp.
443	TCP	HTTPS	Apache httpd (TLS)	Самоподписанный сертификат с внутренней информацией (SAN).
6379	TCP	Redis	Redis Key-Value Store	Открыт сервис Redis.
8000	TCP	HTTP	nginx 1.27.5	Приложение Legacy Billing с открытым репозиторием `.git`.

СТРАНИЦА ОРИГИНАЛА 08 / 47

Порт	Протокол	Сервис	Версия / баннер	Примечания
8080	TCP	HTTP	Caddy httpd	Панель мониторинга доступна без аутентификации.

4.2. Виртуальные хосты и значимые пути

Хост / путь	Способ обнаружения	Примечания
www.megacorp.lab	Сертификат TLS (SAN)	Корпоративный веб-сайт.
dev.megacorp.lab	Сертификат TLS (SAN)	Среда разработки; указано, что просмотр содержимого каталогов включен.
admin.megacorp.lab	Сертификат TLS (SAN)	Виртуальный хост, выявленный при перечислении ресурсов.
api.megacorp.lab	Сертификат TLS (SAN)	Публичный API; ссылка на `/swagger.json`.
internal.megacorp.lab	Сертификат TLS + перечисление с помощью Host	Внутренний хост, доступный без аутентификации; содержит конфиденциальную информацию и FLAG.
staging.megacorp.lab	Сертификат TLS (SAN)	Предпроизводственная среда; упоминается резервная копия в веб-каталоге.

СТРАНИЦА ОРИГИНАЛА 09 / 47

Хост / путь	Способ обнаружения	Примечания
vpn.megacorp.lab	Сертификат TLS + перечисление с помощью Host	Портал VPN; подтверждает утечку внутренних имен через сертификат TLS.
/.git/	Ручное перечисление ресурсов	Открытый репозиторий Git приложения Legacy Billing (порт 8000).
/swagger.json	Страница API	Каталог конечных точек API.
/status.txt	Страница мониторинга	Ресурс, указанный на панели мониторинга на порту 8080.

Этот раздел обобщает всю поверхность атаки, выявленную вами во время аудита, и хорошо связан с последующими находками.

5. ПОДРОБНОЕ ОПИСАНИЕ НАХОДОК

Шкала серьезности (справочная)

Степень серьезности	Описание
Критическая	Прямая компрометация: удаленное выполнение кода, кража учетных данных, полный доступ к данным.
Высокая	Значительный доступ или раскрытие конфиденциальных данных при небольших затратах усилий.
Средняя	Требует определенных условий или цепочки действий; умеренное воздействие.
Низкая	Ограниченное воздействие либо сложность эксплуатации.
Информационная	Рекомендации по передовым практикам / повышение осведомленности, без прямого воздействия.

[F-01] Анонимный доступ к сервису FTP

Поле / значение

СТРАНИЦА ОРИГИНАЛА 10 / 47

Поле	Значение
ID	F-01
Серьезность	Средняя
CVSS 3.1	5.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
Затронутый актив	3.88.28.22:21/tcp
Категория	Небезопасная конфигурация / анонимный доступ к FTP
Статус	Открыто

Описание

На этапе разведки обнаружен доступный из Интернета сервис FTP (vsftpd 3.0.3) с включенной анонимной аутентификацией. Эта настройка позволяет любому пользователю подключиться к серверу без учетных данных и раскрывает информацию, которая может облегчить последующие атаки.

Воздействие

Анонимный доступ к FTP увеличивает поверхность атаки, позволяя неаутентифицированным пользователям просматривать и скачивать файлы, хранящиеся на сервере. Раскрытие этой информации может привести к разглашению конфиденциальных данных и облегчить эксплуатацию других уязвимостей.

Доказательства / подтверждение концепции

Разведка сервиса

```
nmap -sC -sV 3.88.28.22
```

Значимый фрагмент:

```
21/tcp open ftp vsftpd 3.0.3
```

Перевод: порт `21/tcp` открыт; сервис FTP; версия vsftpd 3.0.3.

СТРАНИЦА ОРИГИНАЛА 11 / 47

```
ftp-anon: Anonymous FTP login allowed (FTP code 230)
-r--r--r-- 1 0 0 138 Jun 25 16:10 flag.txt
-r--r--r-- 1 0 0 431 Jun 25 16:10 welcome.txt
```

Перевод: разрешен анонимный вход по FTP (код FTP 230). Доступны файлы `flag.txt` (138 байт) и `welcome.txt` (431 байт), оба от 25 июня, 16:10; права доступа указаны в исходном выводе.

Ручная проверка

```
ftp 3.88.28.22
```

Пользователь: `anonymous`

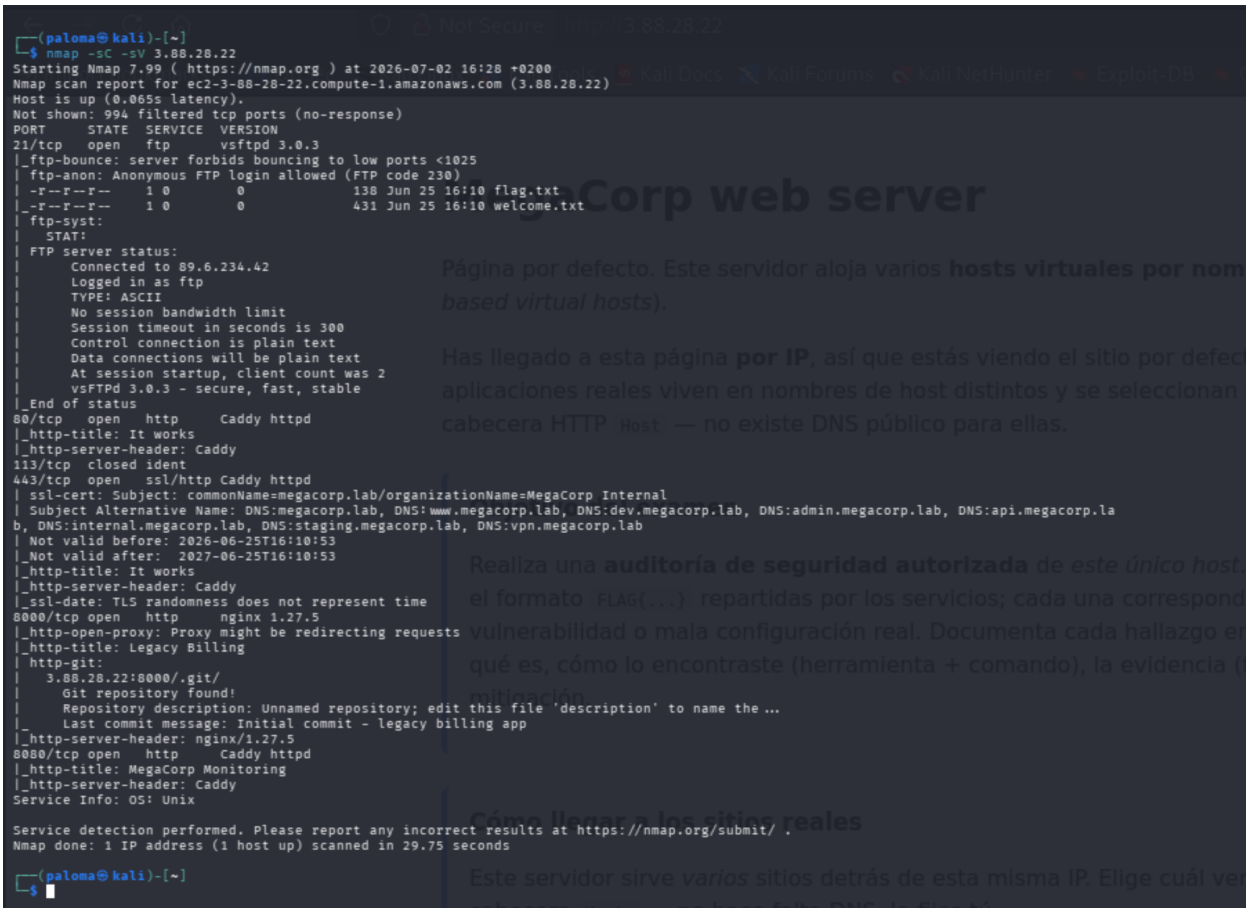
Выполненные команды:

```
ls
get flag.txt
bye
cat flag.txt
```

Полученный флаг

```
FLAG{ftp_anonymous_access}
```

Снимок экрана с доказательством:



Перевод сообщений на снимке экрана

Запуск Nmap 7.99 (`https://nmap.org`) 2026-07-02 в 16:28 +0200. Отчет сканирования для `ec2-3-88-28-22.compute-1.amazonaws.com (3.88.28.22)`. Хост доступен; задержка 0,065 с. Не показаны 994 отфильтрованных TCP-порта, не ответивших на запросы. Заголовки таблицы: порт, состояние, сервис, версия.

FTP: сервер запрещает перенаправление FTP-соединений на низкие порты <1025. Анонимный вход разрешен, код 230. Состояние FTP-сервера: подключение к `89.6.234.42`; вход выполнен как `ftp`; тип ASCII; ограничение пропускной способности сеанса отсутствует; время ожидания сеанса 300 секунд; управляющее соединение и соединения данных передаются открытым текстом; при запуске сеанса подключены 2 клиента. vsFTPd 3.0.3: «безопасный, быстрый, стабильный». Конец сведений о состоянии.

Порты 80 и 443 открыты; HTTP/HTTPS обслуживает Caddy. Заголовок страницы «Работает». Порт 113 закрыт, сервис ident. Сертификат содержит имя субъекта и альтернативные имена, перечисленные в отчете; действует с `2026-06-25T16:10:53` до `2027-06-25T16:10:53`. Случайные данные TLS не представляют время.

На порту 8000: nginx 1.27.5, заголовок «Устаревшая система выставления счетов»; прокси, возможно, перенаправляет запросы. Найден репозиторий Git по адресу `3.88.28.22:8000/.git/`. Описание: «Безымянный репозиторий; отредактируйте файл description, чтобы задать имя...». Последнее сообщение коммита: «Начальный коммит - устаревшее приложение выставления счетов». На порту 8080: Caddy, заголовок «Мониторинг MegaCorp». Информация о сервисах: ОС Unix. Определение сервисов выполнено; о неверных результатах предлагается сообщить на `https://nmap.org/submit/`. Просканирован 1 IP-адрес, 1 доступный хост; время 29,75 секунды.

СТРАНИЦА ОРИГИНАЛА 12 / 47

Рисунок 1. Первичная разведка с помощью Nmap.

Выполнено разведывательное сканирование Nmap с параметрами `-sC` и `-sV` для определения открытых сервисов и их версий. Анализ выявил несколько открытых портов, включая FTP (21), HTTP (80), HTTPS (443), HTTP (8000) и HTTP (8080). Кроме того, скрипт `ftp-anon` обнаружил, что сервер разрешает анонимную аутентификацию, и выявил файлы `flag.txt` и `welcome.txt`. Это указывало на возможную уязвимость конфигурации.

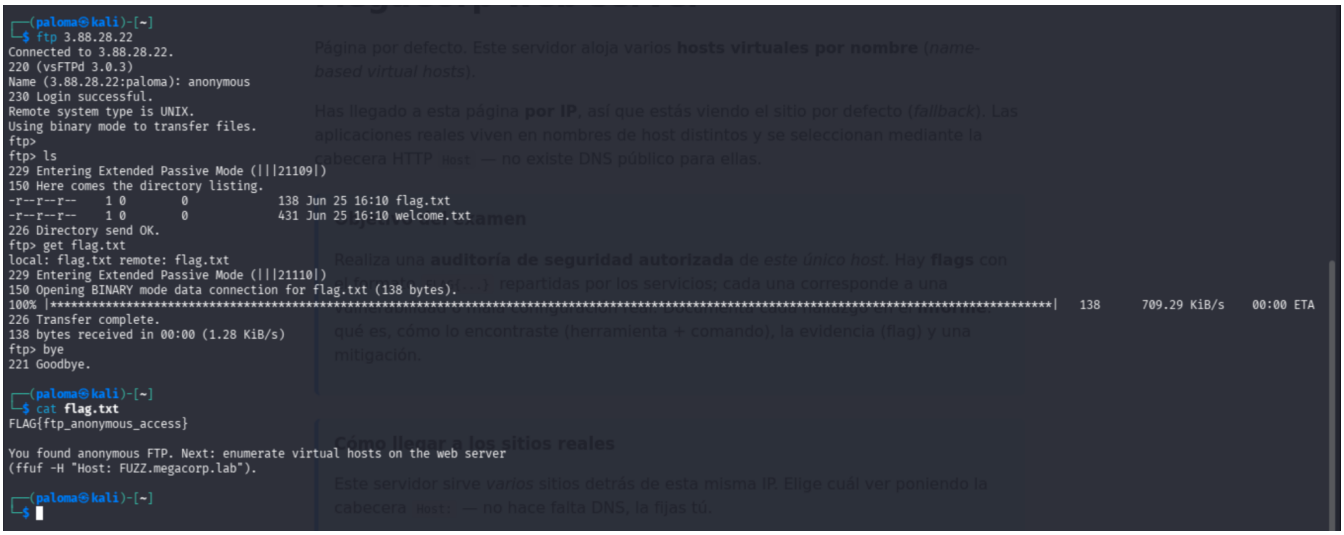


Рисунок 2. Проверка анонимного доступа к FTP.

После обнаружения уязвимости с помощью Nmap ее проверили вручную, подключившись к FTP под пользователем `anonymous`. После входа было просмотрено содержимое сервера, скачан файл `flag.txt` и проверено его содержимое командой `cat`. Получено доказательство `FLAG{ftp_anonymous_access}`. Эта проверка подтвердила, что сервис FTP разрешает доступ без аутентификации, и подтвердила находку, выявленную на этапе разведки.

Перевод сообщений на снимке экрана: подключено к `3.88.28.22`; сервер vsFTPd 3.0.3; имя пользователя anonymous; вход выполнен успешно. Тип удаленной системы UNIX; для передачи файлов используется двоичный режим. Ответ `229`: переход в расширенный пассивный режим; ответ `150`: начинается передача списка каталога; ответ `226`: передача списка каталога завершена. Показаны `flag.txt` и `welcome.txt`. Для скачивания указан локальный и удаленный файл `flag.txt`; открыт двоичный канал передачи данных, 138 байт; передача завершена. Ответ `221`: до свидания. Вывод файла: `FLAG{ftp_anonymous_access}`. «Вы обнаружили анонимный FTP. Далее: перечислите виртуальные хосты веб-сервера (`ffuf -H 'Host: FUZZ.megacorp.lab'`)».

Шаги воспроизведения

1. Выполнить `nmap -sC -sV 3.88.28.22`.
2. Убедиться, что скрипт `ftp-anon` сообщает о разрешенном анонимном доступе.
3. Подключиться командой `ftp 3.88.28.22`.
4. Войти как `anonymous`.
5. Просмотреть содержимое сервера командой `ls`.
6. Скачать файл `flag.txt` командой `get flag.txt`.
7. Показать его содержимое командой `cat flag.txt` и проверить флаг `FLAG{ftp_anonymous_access}`.

СТРАНИЦА ОРИГИНАЛА 13 / 47

Рекомендуемые меры устранения

- Отключить анонимный доступ к FTP.
- Разрешить аутентификацию только авторизованным пользователям.
- Ограничить доступ к сервису с помощью межсетевого экрана или списков контроля доступа.
- Заменить FTP зашифрованными протоколами, например SFTP или FTPS.

Ссылки

- CWE-306 - отсутствие аутентификации для критически важной функции.
- OWASP ASVS 4.0 - V14 «Безопасная конфигурация».
- CIS Controls v8 - управление безопасной конфигурацией.

Небольшая деталь: в выводе `cat flag.txt` есть подсказка... [1]

[F-02] Раскрытие информации через robots.txt

Поле	Значение
ID	F-02
Серьезность	Низкая
CVSS 3.1	3.7 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N) (необязательно)
Затронутый актив	www.megacorp.lab (/robots.txt)
Категория	Раскрытие информации
Статус	Открыто

[1] «Далее: перечислите виртуальные хосты веб-сервера (`ffuf -H 'Host: FUZZ.megacorp.lab'`)». Это не является доказательством уязвимости. Я бы использовала эту подсказку просто как отправную точку для следующей находки - перечисления виртуальных хостов.

Описание

Файл `robots.txt` раскрывает информацию о внутренней структуре приложения, указывая конфиденциальные каталоги (`/admin`, `/backup` и `/uploads`), которые не должны быть публичными. Кроме того, в нем есть комментарий о существовании виртуального хоста предпроизводственной среды (staging), что дает полезную информацию для этапа разведки.

Воздействие

Хотя сам по себе `robots.txt` не предоставляет доступ, он облегчает разведку целевого объекта и позволяет атакующему выявить потенциально конфиденциальные ресурсы и новые точки входа, сокращая усилия, необходимые для продолжения аудита или атаки.

Доказательства / подтверждение концепции

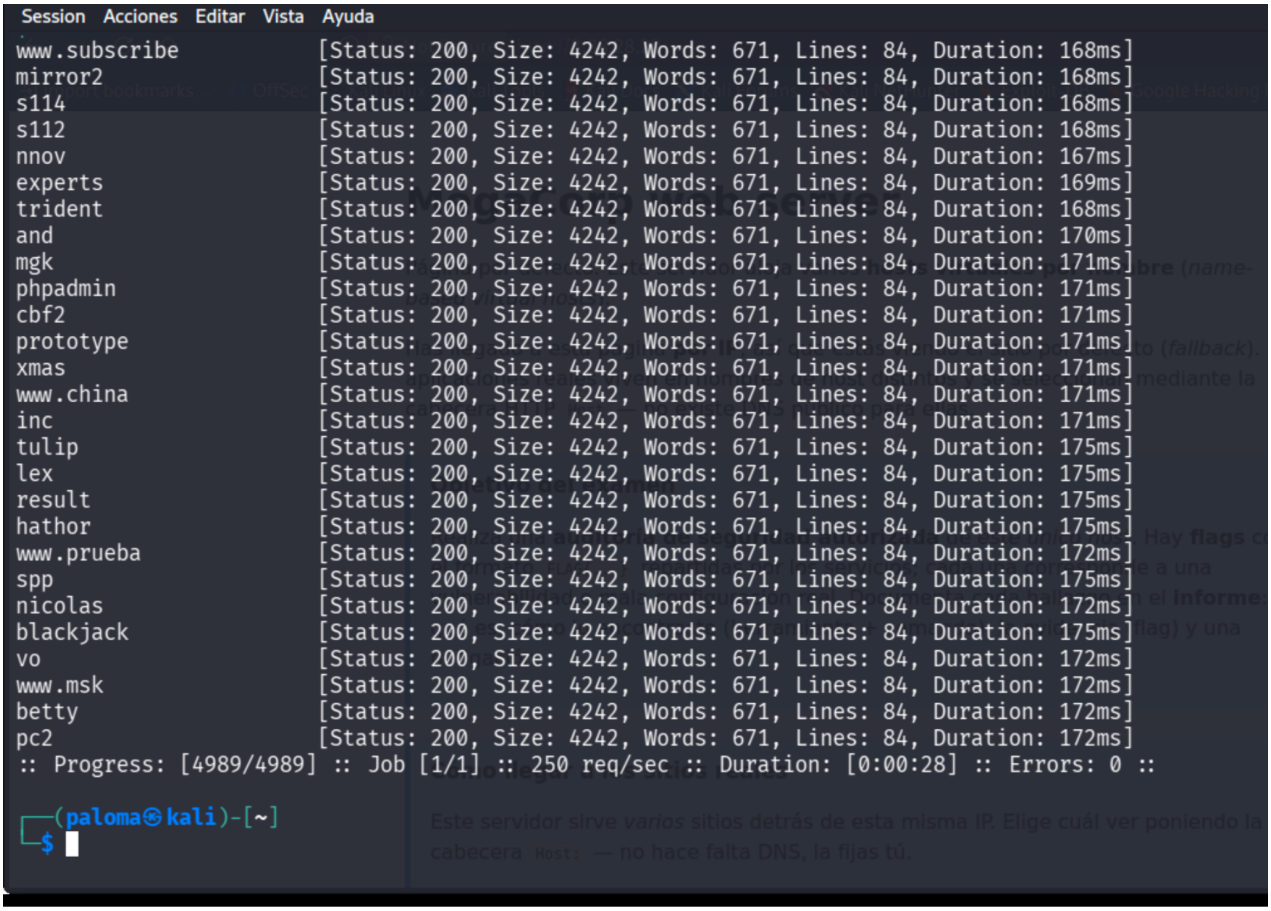
```
curl -H "Host: www.megacorp.lab" http://3.88.28.22/robots.txt
```

Значимый вывод:

```
User-agent: *
Disallow: /admin
Disallow: /backup
Disallow: /uploads
# staging area moved to a separate virtual host
```

Перевод: для всех поисковых роботов запрещена индексация `/admin`, `/backup` и `/uploads`.
Комментарий: «Предпроизводственная среда перенесена на отдельный виртуальный хост».

Доказательство:



Перевод обозначений на снимке: состояние ответа; размер; число слов; число строк; длительность. Показанные варианты имен возвращают состояние 200, размер 4242, 671 слово и 84 строки; время ответа указано в миллисекундах. Ход выполнения: 4989/4989; задание 1/1; 250 запросов/с; длительность 0:00:28; ошибок 0. Элементы меню: «Сеанс», «Действия», «Правка», «Вид», «Справка». Повторяющийся фоновый текст страницы сервера переведен на странице оригинала 2.

СТРАНИЦА ОРИГИНАЛА 15 / 47

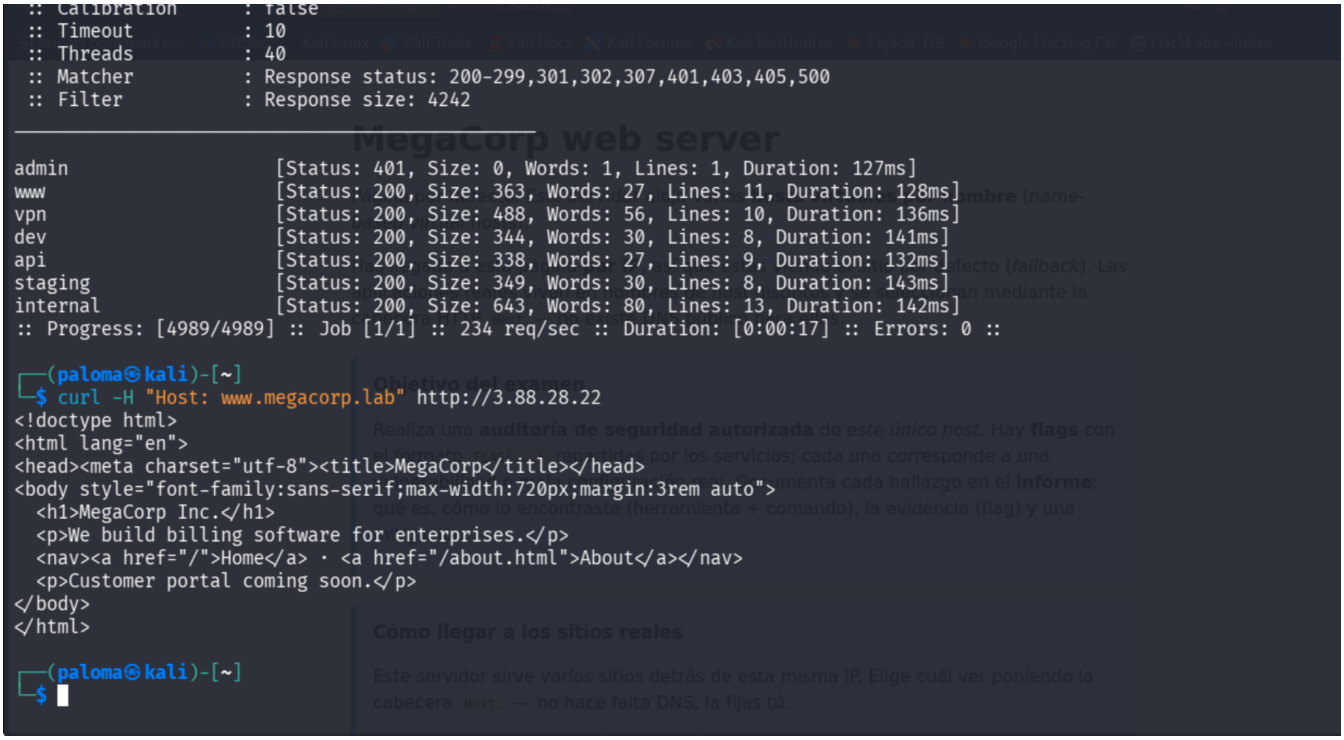


Рисунок 3. Перечисление виртуальных хостов с помощью FFUF.

На этом этапе инструмент FFUF использовался для перебора значений HTTP-заголовка `Host` с целью определения различных виртуальных хостов (Virtual Hosts), настроенных на веб-сервере. После фильтрации ответа страницы по умолчанию (`-fs 4242`) удалось обнаружить несколько действительных виртуальных хостов, включая `www`, `dev`, `api`, `staging`, `internal`, `vpn` и `admin`. Они образуют поверхность атаки сервера и будут проанализированы на следующих этапах аудита. Это позволило обнаружить приложения и сервисы, доступные только при использовании заголовка `Host`, как и было указано в условиях упражнения.

Перевод вывода на снимке: калибровка отключена; время ожидания 10; потоков 40; отбираются ответы со статусами `200-299,301,302,307,401,403,405,500`; фильтр размера ответа 4242.

Хост	Статус	Размер	Слов	Строк	Длительность
admin	401	0	1	1	127 мс
www	200	363	27	11	128 мс
vpn	200	488	56	10	136 мс
dev	200	344	30	8	141 мс
api	200	338	27	9	132 мс
staging	200	349	30	8	143 мс
internal	200	643	80	13	142 мс

Выполнено 4989/4989; задание 1/1; 234 запроса/с; длительность 0:00:17; ошибок 0. Ответ сайта: «MegaCorp Inc. Мы создаем программное обеспечение для выставления счетов предприятиям». Навигация: «Главная», «О компании». «Клиентский портал появится скоро».



Рисунок 4. Выявление конфиденциальной информации через файл robots.txt.

После обнаружения виртуального хоста `www.megacorp.lab` был запрошен файл `robots.txt` с соответствующим заголовком `Host`. В нем найдены каталоги, помеченные как не подлежащие индексации (`/admin`, `/backup` и `/uploads`), а также комментарий о том, что предпроизводственная среда перенесена на отдельный виртуальный хост. Это является утечкой информации: аудитору предоставляются возможные пути и сервисы, представляющие интерес для продолжения перечисления ресурсов и расширения поверхности атаки целевого объекта.

Текст ответа на снимке переведен на странице оригинала 14.

СТРАНИЦА ОРИГИНАЛА 16 / 47

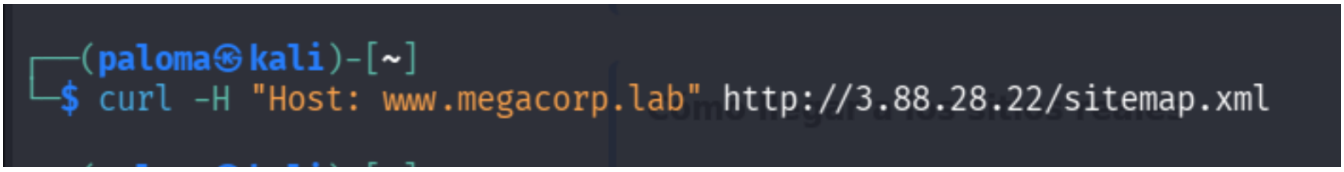


Рисунок 5. Проверка наличия файла sitemap.xml.

На этапе перечисления веб-ресурсов была предпринята попытка получить файл `sitemap.xml` виртуального хоста `www.megacorp.lab` с помощью `curl`. Запрос не вернул содержимого или значимой информации, поэтому был сделан вывод, что ресурс недоступен либо не настроен на сервере. Это позволило исключить данное направление поиска и продолжить аудит с использованием других источников информации: файла `robots.txt` и ранее обнаруженных виртуальных хостов.

Полученный флаг: неприменимо [2].

Шаги воспроизведения

1. Обнаружить виртуальный хост `www.megacorp.lab`.
2. Запросить ресурс `/robots.txt`.
3. Проанализировать раскрытые каталоги и комментарии.

Рекомендуемые меры устранения

- Не включать комментарии, раскрывающие информацию об инфраструктуре.
- Не использовать `robots.txt` для сокрытия конфиденциальных ресурсов.
- Ограничить доступ к административным каталогам с помощью аутентификации и надлежащих механизмов контроля доступа.

Ссылки

- OWASP WSTG - сбор информации.
- CWE-200 - раскрытие конфиденциальной информации неавторизованному субъекту.

[2] Почему флаг для robots.txt неприменим? Потому что каждый флаг соответствует реальной уязвимости или ошибке конфигурации. В FTP был получен флаг `FLAG{ftp_anonymous_access}`, что подтверждает намеренное включение анонимного FTP-доступа в число находок. В отличие от этого, robots.txt не содержит флага. Это лишь «подсказка» для продолжения аудита.

[F-03] Раскрытие конфиденциальной информации предпроизводственной среды (Staging)

Поле	Значение
ID	F-03
Серьезность	Средняя
CVSS 3.1	5.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N) (необязательно)
Затронутый актив	staging.megacorp.lab
Категория	Раскрытие информации
Статус	Открыто

Описание

При перечислении виртуальных хостов обнаружена предпроизводственная среда `staging.megacorp.lab`. При обращении к ней выводилась внутренняя информация: это предпроизводственная копия приложения выставления счетов (billing app), просмотр содержимого каталогов включен (Directory listing is on), а в веб-каталоге имеется резервная копия базы данных. Эта информация не должна быть доступна извне, поскольку дает атакующему очень ценные подсказки.

Воздействие

Раскрытие внутренней информации облегчает следующие этапы атаки, сообщая подробности об инфраструктуре, среде разработки и возможных конфиденциальных ресурсах. Атакующий может использовать эту информацию для поиска резервных копий, исходного кода или открытых конфигураций и последующей компрометации приложения.

СТРАНИЦА ОРИГИНАЛА 18 / 47

Доказательства / подтверждение концепции

Использованные команды

```
curl -H "Host: staging.megacorp.lab" http://3.88.28.22

ffuf \
-u http://3.88.28.22/FUZZ \
-H "Host: staging.megacorp.lab" \
-w /usr/share/seclists/Discovery/Web-Content/raft-small-files.txt \
-e .sql,.zip,.bak,.old,.gz,.tar,.tgz,.db,.sqlite,.sqlite3,.7z
```

Значимый вывод

```
Pre-production mirror of the billing app.
Directory listing is on.
Someone dumped a database backup in the web root again.
```

Перевод:

> Предпроизводственная копия приложения выставления счетов. Просмотр содержимого каталогов включен. Кто-то снова оставил резервную копию базы данных в корневом веб-каталоге.

Кроме того, выполнялось перечисление файлов с помощью `ffuf`, однако на этом этапе указанную сервером резервную копию обнаружить не удалось.

СТРАНИЦА ОРИГИНАЛА 19 / 47

```
┌──(paloma㉿kali)-[~]
└─$ curl -H "Host: staging.megacorp.lab" http://3.88.28.22
<!doctype html>
<html lang="en"><head><meta charset="utf-8"><title>staging.megacorp.lab</title></head>
<body style="font-family:sans-serif;max-width:720px;margin:3rem auto">
  <h1>Staging</h1>
  <p>Pre-production mirror of the billing app. Directory listing is on.</p>
  <p>Someone dumped a database backup in the web root again.</p>
</body></html>

┌──(paloma㉿kali)-[~]
└─$ curl -H "Host: staging.megacorp.lab" http://3.88.28.22 | head -40
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left  Speed
100   349 100   349    0     0  1639      0  --:--:-- --:--:-- --:--:--  1646
<!doctype html>
<html lang="en"><head><meta charset="utf-8"><title>staging.megacorp.lab</title></head>
<body style="font-family:sans-serif;max-width:720px;margin:3rem auto">
  <h1>Staging</h1>
  <p>Pre-production mirror of the billing app. Directory listing is on.</p>
  <p>Someone dumped a database backup in the web root again.</p>
</body></html>

┌──(paloma㉿kali)-[~]
└─$
```

Рисунок 5. Доступ к виртуальному хосту staging.megacorp.lab с помощью заголовка Host и curl. Ответ сервера показывает, что это предпроизводственная среда приложения, сообщает о включенном просмотре содержимого каталогов и наличии резервной копии базы данных в веб-каталоге. Таким образом раскрывается конфиденциальная информация, полезная для продолжения аудита.

Текст страницы: заголовок «Предпроизводственная среда»; далее - сообщение, переведенное на странице оригинала 18. В таблице передачи cURL указаны общий объем, полученные и отправленные данные, средняя скорость, время, оставшееся время и текущая скорость. Получено 349 байт, 100%; скорость 1639 байт/с.

```
┌──(paloma㉿kali)-[~]
└─$ curl -H "Host: staging.megacorp.lab" http://3.88.28.22/backup.sql

┌──(paloma㉿kali)-[~]
└─$ curl -H "Host: staging.megacorp.lab" http://3.88.28.22/backup.zip

┌──(paloma㉿kali)-[~]
└─$ curl -H "Host: staging.megacorp.lab" http://3.88.28.22/backup.tar.gz

┌──(paloma㉿kali)-[~]
└─$ curl -H "Host: staging.megacorp.lab" http://3.88.28.22/database.sql

┌──(paloma㉿kali)-[~]
└─$
```

Рисунок 6. Ручная проверка с помощью curl имен файлов резервных копий, предполагаемых по информации предпроизводственной среды (`backup.sql`, `backup.zip`, `backup.tar.gz` и `database.sql`). Эта проверка проводилась, чтобы выяснить, доступна ли какая-либо резервная копия публично через веб-сервер и содержит ли она конфиденциальную информацию.

СТРАНИЦА ОРИГИНАЛА 20 / 47

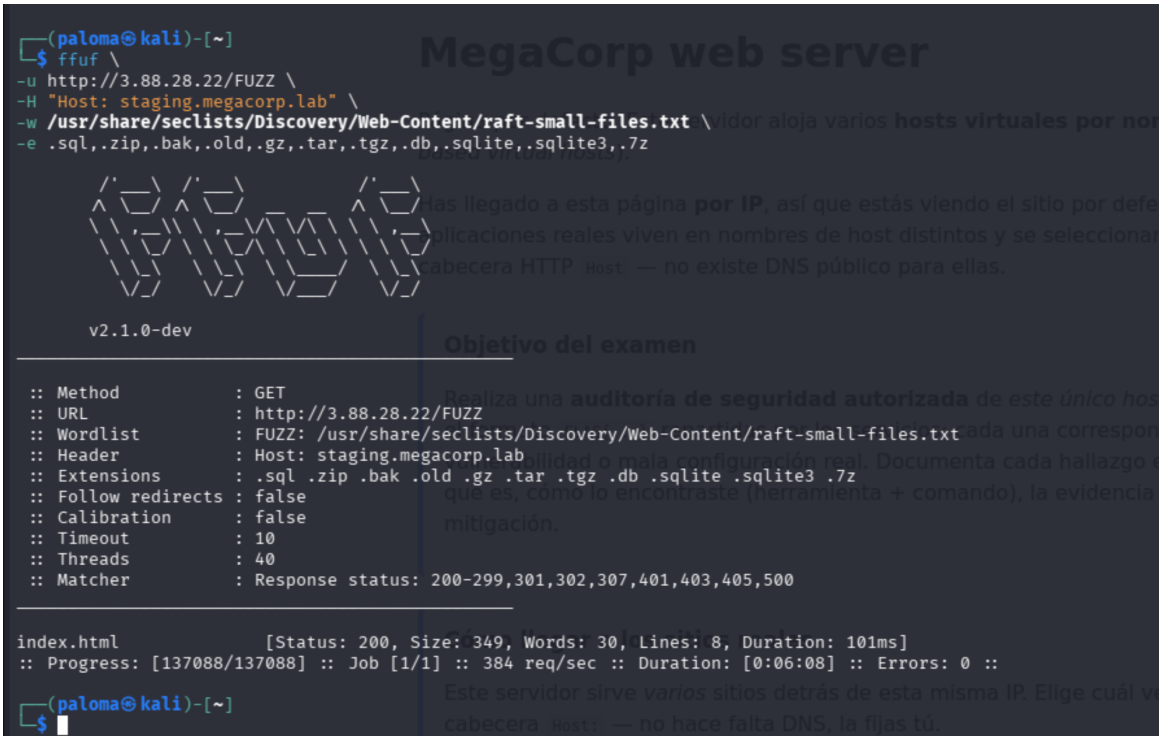


Рисунок 7. Запуск ffuf для виртуального хоста staging.megacorp.lab со словарем имен файлов и распространенными расширениями резервных копий (`.sql`, `.zip`, `.bak`, `.gz`, `.tar` и др.). Целью было обнаружение публично доступных конфиденциальных файлов. В ходе проверки был найден только `index.html`, поэтому доступных резервных копий с наиболее распространенными именами обнаружено не было.

Перевод параметров и результата на снимке: ffuf v2.1.0-dev; метод GET; URL `http://3.88.28.22/FUZZ`; словарь `FUZZ`: `/usr/share/seclists/Discovery/Web-Content/raft-small-files.txt`; заголовок `Host: staging.megacorp.lab`; расширения `.sql .zip .bak .old .gz .tar .tgz .db .sqlite .sqlite3 .7z`. Следование перенаправлениям отключено; калибровка отключена; время ожидания 10; потоков 40. Отбираются ответы со статусами `200-299,301,302,307,401,403,405,500`. Результат `index.html`: статус 200, размер 349, 30 слов, 8 строк, длительность 101 мс. Выполнено 137088/137088; задание 1/1; 384 запроса/с; длительность 0:06:08; ошибок 0.

Полученный флаг: неприменимо.

Шаги воспроизведения

1. Обнаружить виртуальный хост `staging.megacorp.lab` путем перечисления виртуальных хостов.
2. Обратиться к хосту с помощью заголовка `Host`.
3. Изучить внутреннюю информацию, показанную на странице.
4. Перебрать возможные имена файлов резервных копий, чтобы попытаться обнаружить упомянутые ресурсы.

Рекомендуемые меры устранения

- Закрыть публичный доступ к предпроизводственной среде.
- Не показывать внутренние или отладочные сообщения в приложениях, доступных из Интернета.
- Отключить просмотр содержимого каталогов.

- Хранить резервные копии вне публичного каталога веб-сервера.

Ссылки

- CWE-200 - раскрытие конфиденциальной информации неавторизованному субъекту.
- OWASP Top 10 2021 - A05: ошибки конфигурации безопасности.
- OWASP Web Security Testing Guide (WSTG) - сбор информации.

[F-04] Открытая резервная копия базы данных в предпроизводственной среде

Поле	Значение
ID	F-04
Серьезность	Высокая
CVSS 3.1	7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
Затронутый актив	staging.megacorp.lab (/db_backup.sql)
Категория	Раскрытие конфиденциальной информации / публично доступная резервная копия
Статус	Открыто

Описание

В ходе аудита установлено, что в среде `staging.megacorp.lab` открыта резервная копия базы данных (`db_backup.sql`), доступная без аутентификации. Файл

содержит конфиденциальную информацию: структуру базы данных, пользователей, повторно используемые учетные данные и внутренние заметки среды разработки.

Воздействие

Атакующий может получить конфиденциальную информацию о приложении, повторно использовать учетные данные в других сервисах, изучить структуру базы данных и применить эти сведения для подготовки последующих атак. Кроме того, сам файл раскрывает дополнительную информацию о других внутренних сервисах, облегчая боковое перемещение по инфраструктуре.

Доказательства / подтверждение концепции

Использованная команда

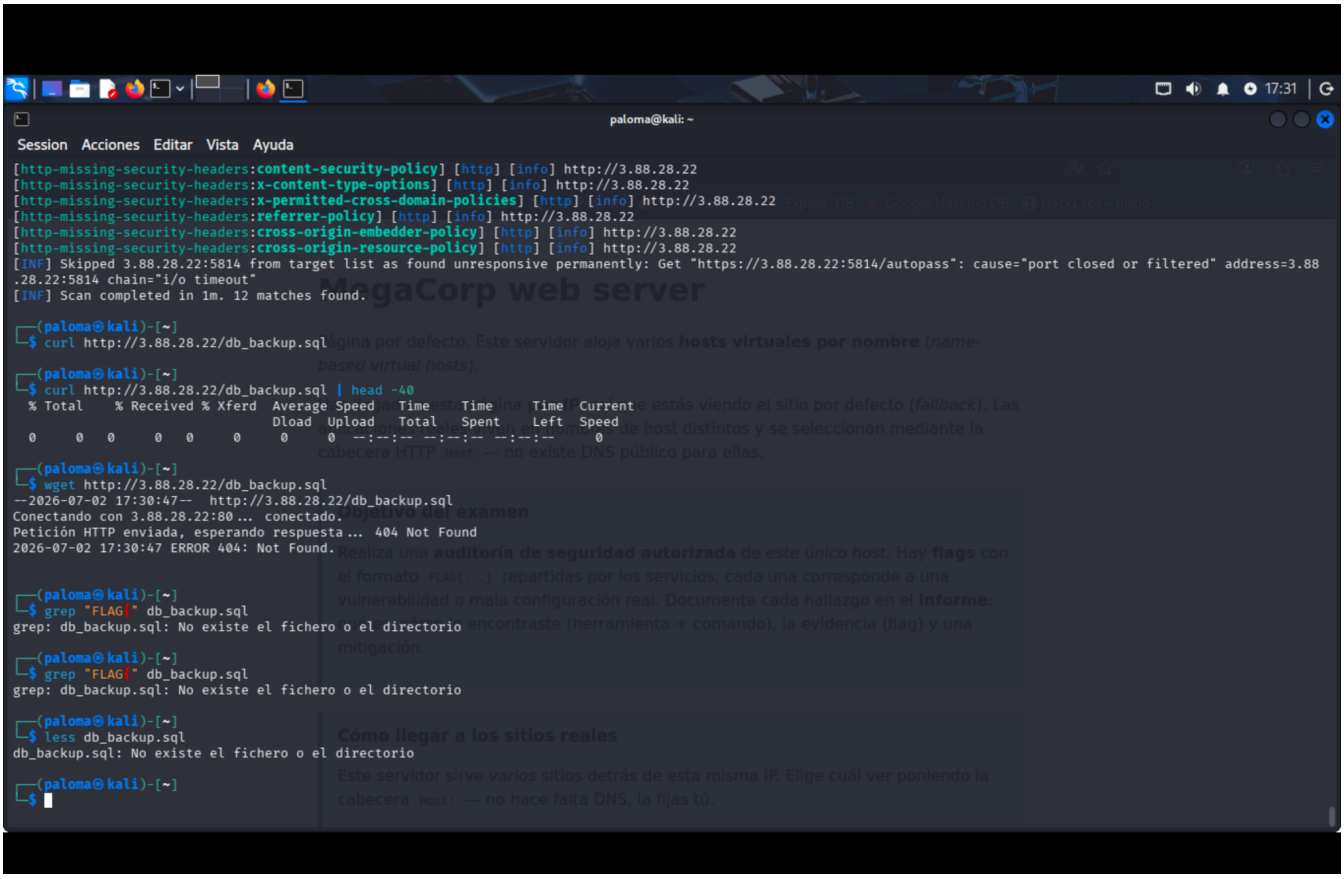
```
curl -H "Host: staging.megacorp.lab" http://3.88.28.22/db_backup.sql
```

Значимый вывод

```
-- MegaCorp billing DB - staging backup
FLAG{staging_sql_backup}
Note: Same DB password as dev (Sup3rDevPassw0rd!).
Credential reuse.
Cache: secrets are kept in the unauthenticated Redis node on port 6379.
```

Перевод:

> База данных приложения выставления счетов MegaCorp - резервная копия предпроизводственной среды. `FLAG{staging_sql_backup}`. Примечание: пароль базы данных такой же, как в среде разработки (`Sup3rDevPassw0rd!`). Учетные данные используются повторно. Кэш: секреты хранятся в узле Redis без аутентификации на порту 6379.



Перевод дополнительных сообщений на снимке: отсутствуют HTTP-заголовки безопасности `content-security-policy`, `x-content-type-options`, `x-permitted-cross-domain-policies`, `referrer-policy`, `cross-origin-embedder-policy` и `cross-origin-resource-policy`; уровень - информационный. Узел `3.88.28.22:5814` исключен из списка целей как постоянно не отвечающий; запрос `https://3.88.28.22:5814/autopass`; причина: порт закрыт или фильтруется, истекло время ожидания ввода-вывода. Сканирование завершено за 1 минуту, найдено 12 совпадений.

При запросе cURL счетчики передачи равны нулю. Wget: `2026-07-02 17:30:47`; подключение к `3.88.28.22:80` установлено; HTTP-запрос отправлен, ожидание ответа; `404 Not Found` - «Не найдено». Ошибка 404. Команды `grep` и `less` для `db_backup.sql` сообщают: «Нет такого файла или каталога». Перевод повторяющихся элементов меню и фоновой страницы приведен выше.

СТРАНИЦА ОРИГИНАЛА 23 / 47

Рисунок 8. Первоначальная проверка возможного файла db_backup.sql, обнаруженного Nuclei. Сначала было выполнено несколько проверок с помощью `curl`, `wget`, `grep` и `less` при обращении к хосту по умолчанию. Возвращалась ошибка `404 Not Found` либо сообщение об отсутствии файла. Эта проверка позволила исключить ложное подтверждение доступа и заключить, что ресурс доступен только через соответствующий виртуальный хост с заголовком `Host: staging.megacorp.lab`.

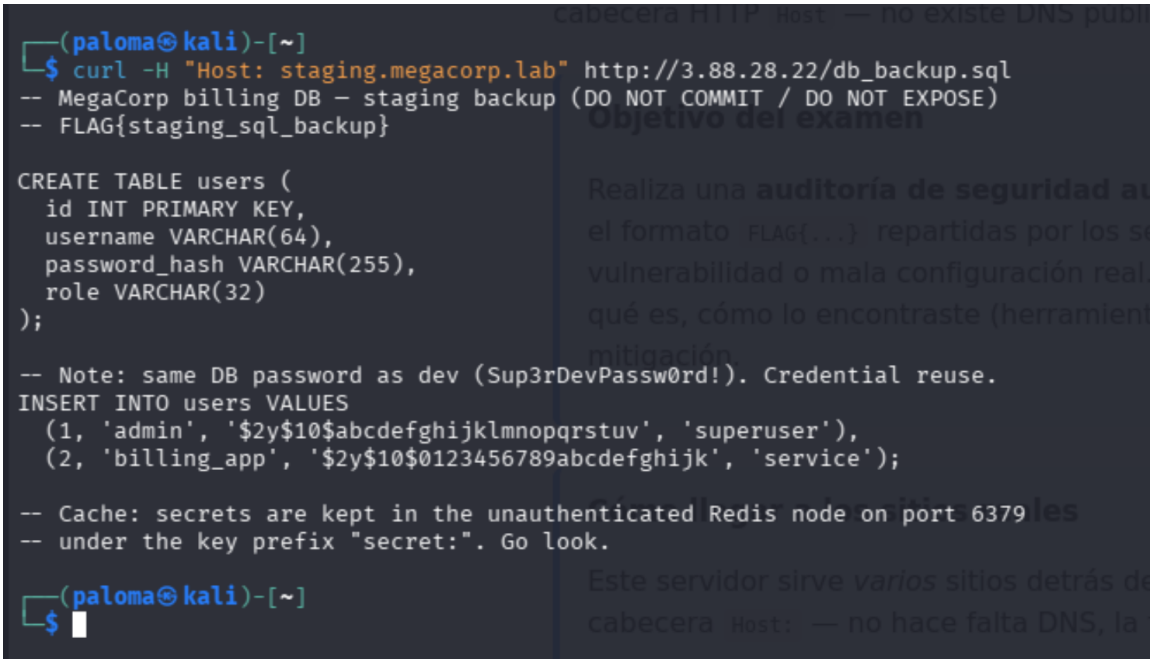


Рисунок 9. Успешный доступ к файлу db_backup.sql среды staging.megacorp.lab с помощью заголовка Host.

Установлено, что резервная копия была общедоступной и содержала конфиденциальные сведения, включая флаг `FLAG{staging_sql_backup}`, указания на повторное использование учетных данных и подсказку о сервисе Redis без аутентификации. Это подтверждает раскрытие критически важной информации.

Перевод текста и комментариев на снимке: «База данных приложения выставления счетов MegaCorp - резервная копия предпроизводственной среды (НЕ ДОБАВЛЯТЬ В КОММИТЫ / НЕ ОТКРЫВАТЬ ДОСТУП)». Далее следует флаг и SQL-код создания таблицы `users` с полями `id`, `username`, `password_hash`, `role`; вставляются записи `admin` с ролью `superuser` и `billing_app` с ролью `service`. Примечание: «Пароль базы данных такой же, как в среде разработки (`Sup3rDevPassw0rd!`). Учетные данные используются повторно». «Кэш: секреты хранятся в узле Redis без аутентификации на порту 6379 под префиксом ключей `secret:`. Посмотрите там». Имена, типы данных, хэши и значения SQL сохраняются в исходном снимке.

Полученный флаг

```
FLAG{staging_sql_backup}
```

Шаги воспроизведения

1. Обнаружить виртуальный хост `staging.megacorp.lab` путем перечисления виртуальных хостов.
2. Обратиться к файлу `db_backup.sql` с соответствующим заголовком `Host`.
3. Убедиться, что сервер возвращает полное содержимое резервной копии вместе с флагом.

СТРАНИЦА ОРИГИНАЛА 24 / 47

Рекомендуемые меры устранения

- Немедленно удалить резервные копии из веб-каталога.
- Ограничить доступ к предпроизводственной среде с помощью аутентификации или сетевой фильтрации.
- Не использовать одни и те же учетные данные в разных средах.
- Регулярно проверять открытость конфиденциальных файлов и исключать резервные копии из размещаемых на веб-сервере данных.

Ссылки

- CWE-530 - доступность файла резервной копии за пределами разрешенной области контроля.
- OWASP Top 10 2021 - A05: ошибки конфигурации безопасности.
- OWASP Testing Guide - проверка утечек информации.

[F-05] Экземпляр Redis, доступный без аутентификации

Поле	Значение
ID	F-05
Серьезность	Высокая
CVSS 3.1	8.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L) (необязательно)
Затронутый актив	3.88.28.22:6379 (Redis)
Категория	Раскрытие информации / сервис без аутентификации
Статус	Открыто

СТРАНИЦА ОРИГИНАЛА 25 / 47

Описание

Выявлен экземпляр Redis, доступный из сети без аутентификации. Это позволяет свободно запрашивать сохраненные ключи и получать доступ к конфиденциальной информации, например секретам приложения и учетным данным.

Воздействие

Удаленный атакующий может получить доступ к конфиденциальной информации, хранящейся в Redis: административным токенам, секретам приложения или учетным данным. Это может облегчить повышение привилегий и компрометацию других сервисов инфраструктуры.

Доказательства / подтверждение концепции

Использованные команды

```
redis-cli -h 3.88.28.22 -p 6379
PING
KEYS *
KEYS secret:*
GET secret:flag
GET secret:admin_token
```

Значимый вывод

```
PONG
KEYS secret:*
1) "secret:admin_token"
2) "secret:flag"
GET secret:flag
FLAG{redis_unauthenticated_access}
GET secret:admin_token
mc_live_8f2a9d1c7b6e4a3f
```

СТРАНИЦА ОРИГИНАЛА 26 / 47



Рисунок 10. Доступ к экземпляру Redis без аутентификации и получение конфиденциальной информации.

На рисунке 10 показано подключение к Redis с помощью `redis-cli` без предоставления учетных данных. После проверки соединения командой `PING` были перечислены сохраненные ключи (`KEYS *` и `KEYS secret:*`) и прочитано их содержимое с помощью `GET`. В результате получены флаг `FLAG{redis_unauthenticated_access}` и административный токен. Это подтверждает, что сервис раскрывает конфиденциальную информацию без какого-либо механизма аутентификации. Такая ситуация представляет высокий риск: атакующий может получить секреты приложения и использовать их для компрометации других сервисов системы.

В исходном выводе также перечислены ключи `cfg:note`, `cfg:db_host`, `secret:admin_token`, `welcome`, `cfg:db_user` и `secret:flag`; это технические имена, они не переводятся. Ответ `PONG` подтверждает ответ на команду `PING`.

Полученный флаг

```
FLAG{redis_unauthenticated_access}
```

Шаги воспроизведения

1. Подключиться к Redis с помощью `redis-cli`.
2. Убедиться с помощью `PING`, что сервис отвечает без аутентификации.
3. Перечислить ключи с помощью `KEYS *` и `KEYS secret:*`.

4. Прочитать их содержимое с помощью `GET secret:flag` и `GET secret:admin_token`.

Рекомендуемые меры устранения

- Включить аутентификацию в Redis (`requirepass` или ACL).
- Ограничить доступ внутренней сетью либо межсетевым экраном.
- Не хранить секреты в текстовом виде, доступном через открытые экземпляры сервиса.
- Немедленно заменить раскрытый административный токен.

Ссылки

- CWE-306 - отсутствие аутентификации для критически важной функции.
- CWE-200 - раскрытие конфиденциальной информации.
- OWASP Top 10 2021 - A01: нарушения контроля доступа.
- OWASP Top 10 2021 - A05: ошибки конфигурации безопасности.

[F-06] Открытый репозиторий Git

Поле	Значение
ID	F-06
Серьезность	Высокая
CVSS 3.1	8.2 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N)
Затронутый актив	http://3.88.28.22:8000/.git/
Категория	Раскрытие исходного кода / разглашение конфиденциальной информации
Статус	Открыто

СТРАНИЦА ОРИГИНАЛА 28 / 47

Описание

Обнаружено, что каталог `.git` на сервере находится в публичном доступе. Это позволило скачать репозиторий Git, восстановить исходный код приложения и получить доступ к внутренним файлам конфигурации, содержащим конфиденциальную информацию об инфраструктуре и хранении секретов.

Воздействие

Открытость репозитория позволяет атакующему изучить внутреннюю работу приложения, выявить уязвимости, получить конфиденциальную информацию и подготовить последующие атаки. В данном случае дополнительно было раскрыто, что секреты приложения хранятся на сервере Redis без аутентификации.

Доказательства / подтверждение концепции

Использованные команды

```
wget -r -np -nH http://3.88.28.22:8000/.git/
git --git-dir=$HOME/.git --work-tree=$HOME/repo checkout -f
grep -R "FLAG{" repo
grep -R "password\|secret\|token\|admin" repo
```

Значимый вывод

```
FLAG{git_source_disclosure}
Application secrets are cached in Redis (port 6379, no authentication).
The master flag is stored under the key: secret:flag
```

Перевод: «Секреты приложения кэшируются в Redis (порт 6379, без аутентификации). Главный флаг хранится под ключом `secret:flag`».

См. рисунки 11 и 12.

СТРАНИЦА ОРИГИНАЛА 29 / 47

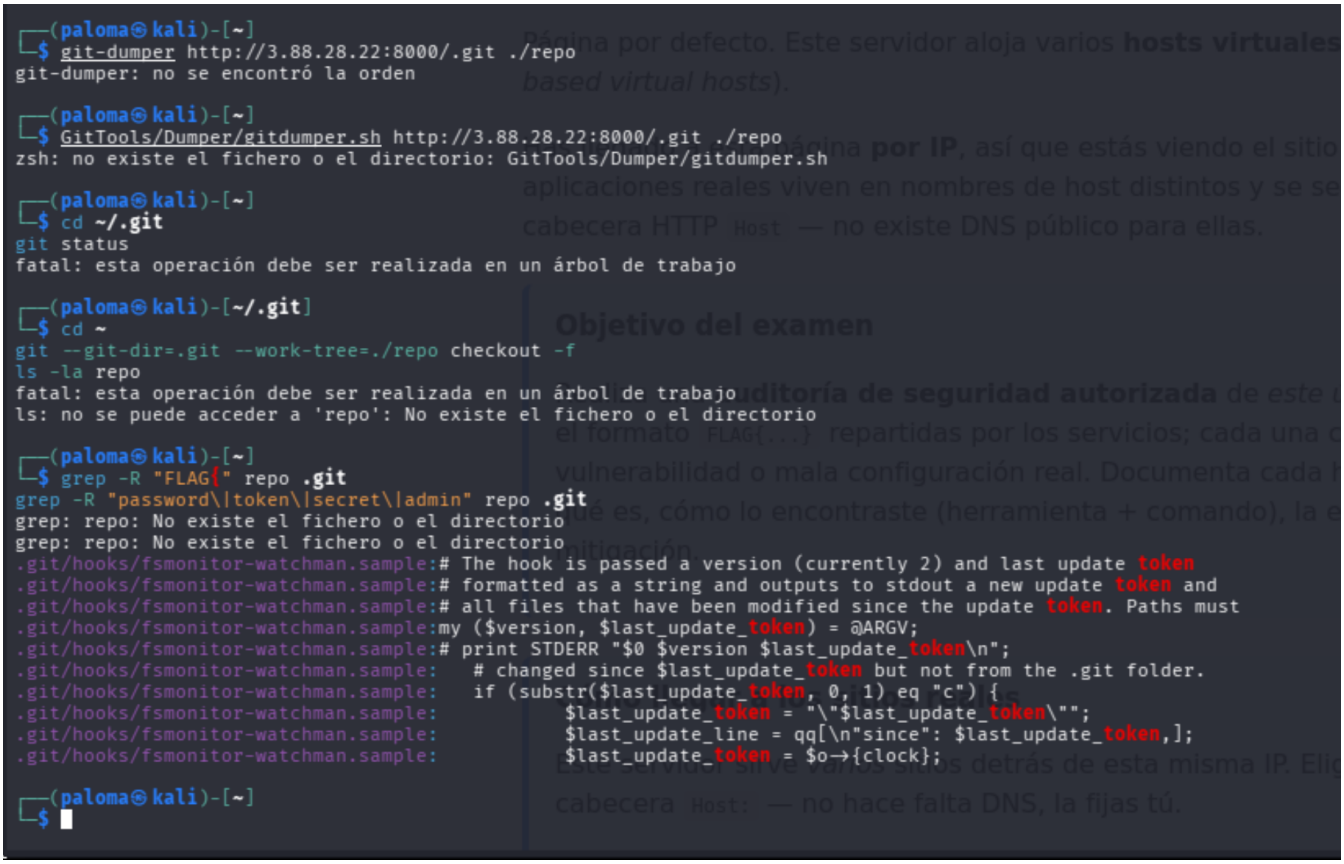
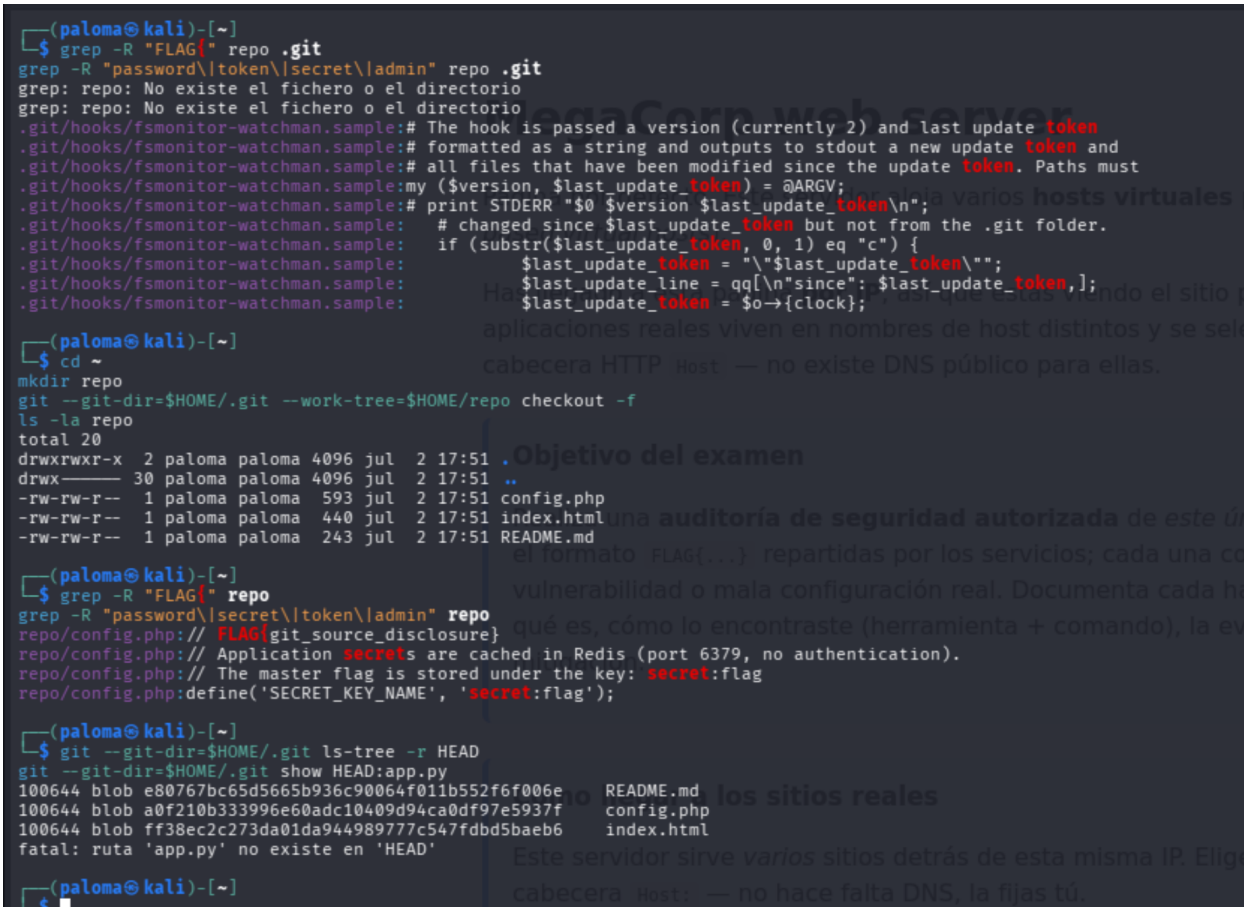


Рисунок 11. Попытки восстановления открытого репозитория Git.

На этом снимке показаны первоначальные попытки восстановления репозитория Git, скачанного с сервера. Хотя первые проверки с помощью `git-dumper` и прямой поиск конфиденциальной информации завершились ошибками из-за отсутствия корректного рабочего дерева, они позволили убедиться, что каталог `.git` доступен и содержит объекты, необходимые для последующего полного восстановления репозитория. Эти данные подтверждают открытость репозитория Git до его окончательного восстановления.

Перевод сообщений на снимке: `git-dumper`: команда не найдена. `GitTools/Dumper/gitdumper.sh`: нет такого файла или каталога. `git status` и первоначальный `checkout`: «Критическая ошибка: эту операцию необходимо выполнять в рабочем дереве». `ls`: нет доступа к `repo`, нет такого файла или каталога. `grep`: каталог `repo` не существует.

В совпадениях из `.git/hooks/fsmonitor-watchman.sample` видны комментарии: «В хук передаются версия (сейчас 2) и токен последнего обновления, представленный строкой; в стандартный вывод он возвращает новый токен обновления и все файлы, измененные после предыдущего токена обновления. Пути должны...». Далее: «измененные после `$last_update_token`, но не из каталога `.git`». Остальное - исходный код примера хука с техническими именами переменных, сохраненный на снимке.



Перевод дополнительных сообщений на втором снимке: повторяются ошибки отсутствия `repo` и приведенные выше комментарии примера хука. После создания рабочего каталога показаны `config.php` (593 байта), `index.html` (440 байт), `README.md` (243 байта); владелец и группа `paloma`, дата 2 июля, 17:51. Вывод `grep` сообщает о флаге и секретах Redis, переведенных на странице оригинала 28. В дереве `HEAD` перечислены объекты `README.md`, `config.php` и `index.html` с режимом `100644`, типом `blob` и их хэшами. Для `app.py`: «Критическая ошибка: путь 'app.py' не существует в 'HEAD'».

СТРАНИЦА ОРИГИНАЛА 30 / 47

Рисунок 12. Восстановление репозитория Git и получение конфиденциальной информации.

На снимке показано успешное восстановление рабочего дерева открытого репозитория Git с помощью `git checkout`. Затем выполняется поиск конфиденциальной информации командой `grep`; в файле `config.php` обнаружен флаг `FLAG{git_source_disclosure}`. Кроме того, исходный код раскрывает, что приложение хранит секреты в экземпляре Redis без аутентификации, и указывает, что главный ключ находится под именем `secret:flag`. Эта информация позволила перейти к следующей находке в цепочке аудита.

Полученный флаг

```
FLAG{git_source_disclosure}
```

Шаги воспроизведения

1. Обратиться к каталогу `http://3.88.28.22:8000/.git/`.
2. Скачать содержимое репозитория.
3. Восстановить рабочее дерево с помощью Git.
4. Проверить полученные файлы на наличие конфиденциальной информации.

Рекомендуемые меры устранения

Заблокировать публичный доступ к каталогу `.git`, удалить любые репозитории из публикуемого веб-каталога, проверять код перед развертыванием на наличие конфиденциальной информации и заменить все учетные данные или секреты, которые могли оказаться раскрытыми.

Ссылки

- CWE-200 - раскрытие конфиденциальной информации неавторизованному субъекту.
- CWE-552 - файлы или каталоги, доступные внешним сторонам.
- OWASP Top 10 2021 - A05: ошибки конфигурации безопасности.

[F-07] Раскрытие исходного кода и конфиденциальной информации (?) [3]

Поле / значение

[3] Примечание: находки F-06 и F-07 соответствуют двум этапам одной цепочки эксплуатации. Они задокументированы отдельно, чтобы различать исходную уязвимость (открытость репозитория Git) и ее прямое воздействие (раскрытие исходного кода и конфиденциальной информации), облегчая прослеживаемость и анализ риска.

СТРАНИЦА ОРИГИНАЛА 31 / 47

Поле	Значение
ID	F-07
Серьезность	Высокая
CVSS 3.1	7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N)
Затронутый актив	http://3.88.28.22:8000/.git/ / восстановленный репозиторий
Категория	Раскрытие исходного кода / разглашение секретов
Статус	Открыто

Описание

После скачивания и восстановления открытого репозитория Git был получен доступ к исходному коду приложения. В файле `config.php` найдены внутренние комментарии, ссылки на секреты, хранящиеся в Redis, и флаг, что подтверждает наличие раскрытой конфиденциальной информации в коде.

Воздействие

Атакующий может проанализировать исходный код, понять внутреннюю логику приложения, найти секреты, выявить вспомогательные сервисы и подготовить последующие атаки. В данном случае код раскрывал, что секреты хранятся в Redis под ключом `secret:flag`.

Доказательства / подтверждение концепции

Использованные команды

```
git --git-dir=$HOME/.git --work-tree=$HOME/repo checkout -f
grep -R "FLAG{" repo
```

СТРАНИЦА ОРИГИНАЛА 32 / 47

```
grep -R "password\|secret\|token\|admin" repo
```

Значимый вывод

```
repo/config.php:// FLAG{git_source_disclosure}
repo/config.php:// Application secrets are cached in Redis (port 6379, no authentication).
repo/config.php:// The master flag is stored under the key: secret:flag
repo/config.php:define('SECRET_KEY_NAME', 'secret:flag');
```

Перевод комментариев: «Секреты приложения кэшируются в Redis (порт 6379, без аутентификации). Главный флаг хранится под ключом `secret:flag`».

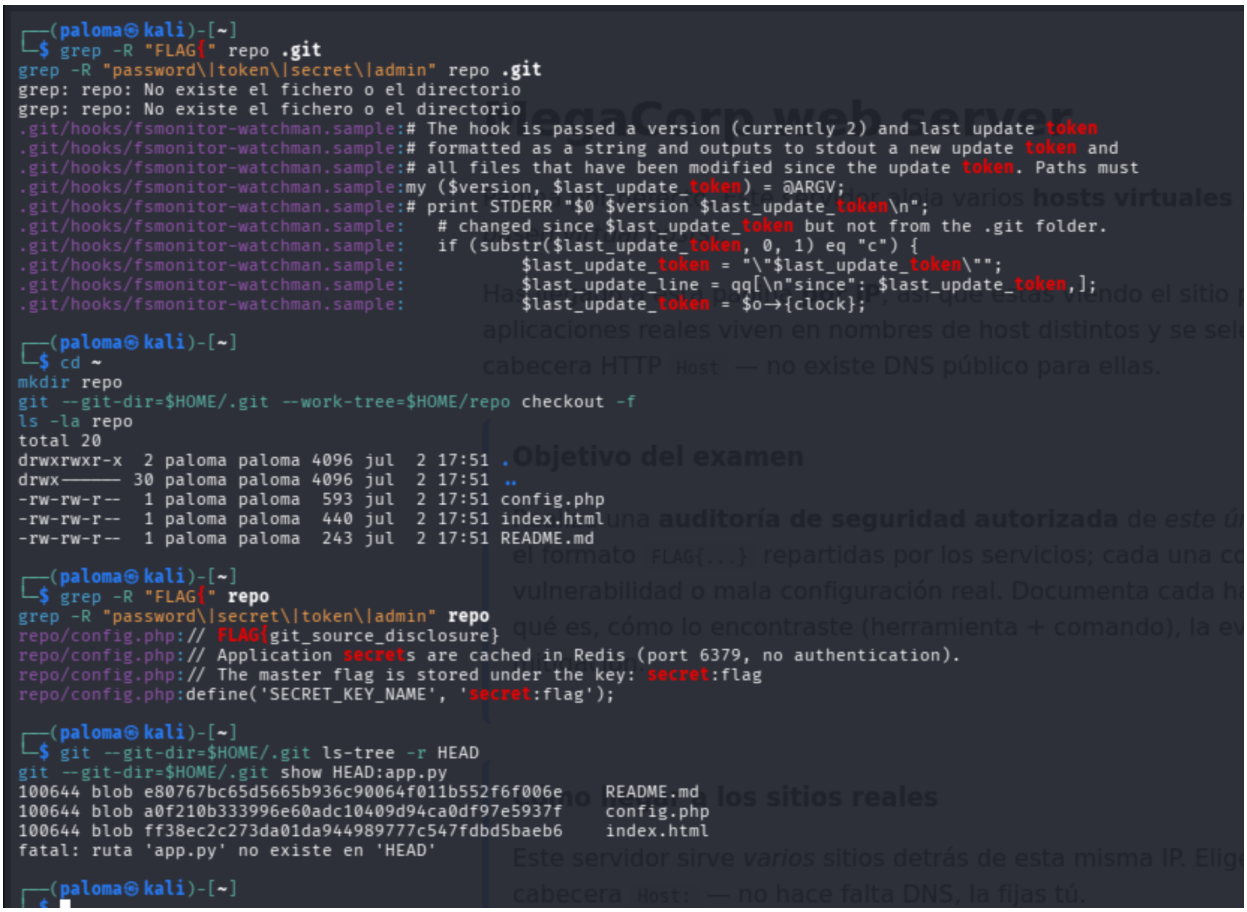


Рисунок 13. Восстановление открытого репозитория Git и анализ полученного исходного кода. Поиск по полученным файлам выявляет конфиденциальную информацию, ссылки на внутренние секреты приложения, имя ключа, используемого для хранения флага в Redis (`secret:flag`), и доказательство `FLAG{git_source_disclosure}`. Это подтверждает раскрытие исходного кода и конфиденциальной информации.

Снимок повторяет изображение на странице оригинала 29; перевод сообщений, комментариев и ошибки `app.py` приведен там же.

СТРАНИЦА ОРИГИНАЛА 33 / 47

Полученный флаг

```
FLAG{git_source_disclosure}
```

Шаги воспроизведения

1. Скачать открытый каталог `.git` через порт 8000.
2. Восстановить рабочее дерево репозитория.
3. Найти флаги и секреты в исходном коде.
4. Проверить файл `config.php`.

Рекомендуемые меры устранения

Удалить репозиторий Git из публичного каталога, заблокировать доступ к `.git` на веб-сервере, проверить исходный код и удалить секреты или конфиденциальные комментарии, а также заменить все раскрытые учетные данные.

Ссылки

- CWE-200 - раскрытие конфиденциальной информации.
- CWE-540 - включение конфиденциальной информации в исходный код.
- OWASP Top 10 2021 - A05: ошибки конфигурации безопасности.

F-08 - Самоподписанный сертификат TLS и раскрытие внутренней информации

Описание

При анализе сервиса HTTPS установлено, что сервер использует самоподписанный сертификат TLS (self-signed). Кроме того, сертификат раскрывает внутреннюю информацию об инфраструктуре MegaCorp через общее имя (CN) и расширение Subject Alternative Name (SAN - альтернативное имя субъекта), в котором указано несколько внутренних имен хостов.

Доказательства

Использованный инструмент:

```
openssl s_client -connect 3.88.28.22:443 -servername megacorp.lab </dev/null | openssl x509 -noout
-text
```

Полученные результаты:

```
verify error:num=18:self-signed certificate
```

Перевод: ошибка проверки № 18 - самоподписанный сертификат.

СТРАНИЦА ОРИГИНАЛА 34 / 47

```
Subject:
CN=megacorp.lab
O=MegaCorp Internal

Subject Alternative Name:
DNS:megacorp.lab
DNS:www.megacorp.lab
DNS:dev.megacorp.lab
DNS:admin.megacorp.lab
DNS:api.megacorp.lab
DNS:internal.megacorp.lab
DNS:staging.megacorp.lab
DNS:vpn.megacorp.lab
```

Перевод названий полей: `Subject` - субъект сертификата; `CN` - общее имя; `O` - организация; `Subject Alternative Name` - альтернативное имя субъекта. Значения имен сохранены без изменений.

Воздействие

- Использование самоподписанного сертификата не позволяет проверить подлинность сервера через доверенный удостоверяющий центр.
- Раскрытие внутренних имен облегчает разведку (reconnaissance) потенциальному атакующему.
- Открытые имена поддоменов могут стать отправной точкой для выявления административных сервисов или потенциально уязвимых сред разработки.

Серьезность

Средняя.

Рекомендации

- Для сервисов, доступных извне, использовать сертификаты, выданные доверенным удостоверяющим центром (CA).
- Не включать ненужные внутренние имена в публично доступные сертификаты.

- Разделить сертификаты, используемые во внутренних и производственных средах, чтобы минимизировать раскрытие информации об инфраструктуре.

F-09 - Доступ к внутреннему виртуальному хосту путем перечисления значений заголовка Host

Описание

При перечислении виртуальных хостов с использованием имен, извлеченных из сертификата TLS, был обнаружен сайт `internal.megacorp.lab`. Этот хост, по-видимому предназначенный для внутреннего использования, был доступен при простом изменении HTTP-заголовка `Host`. Никаких механизмов аутентификации или контроля доступа, препятствующих просмотру, не было.

Доказательства

Использованная команда:

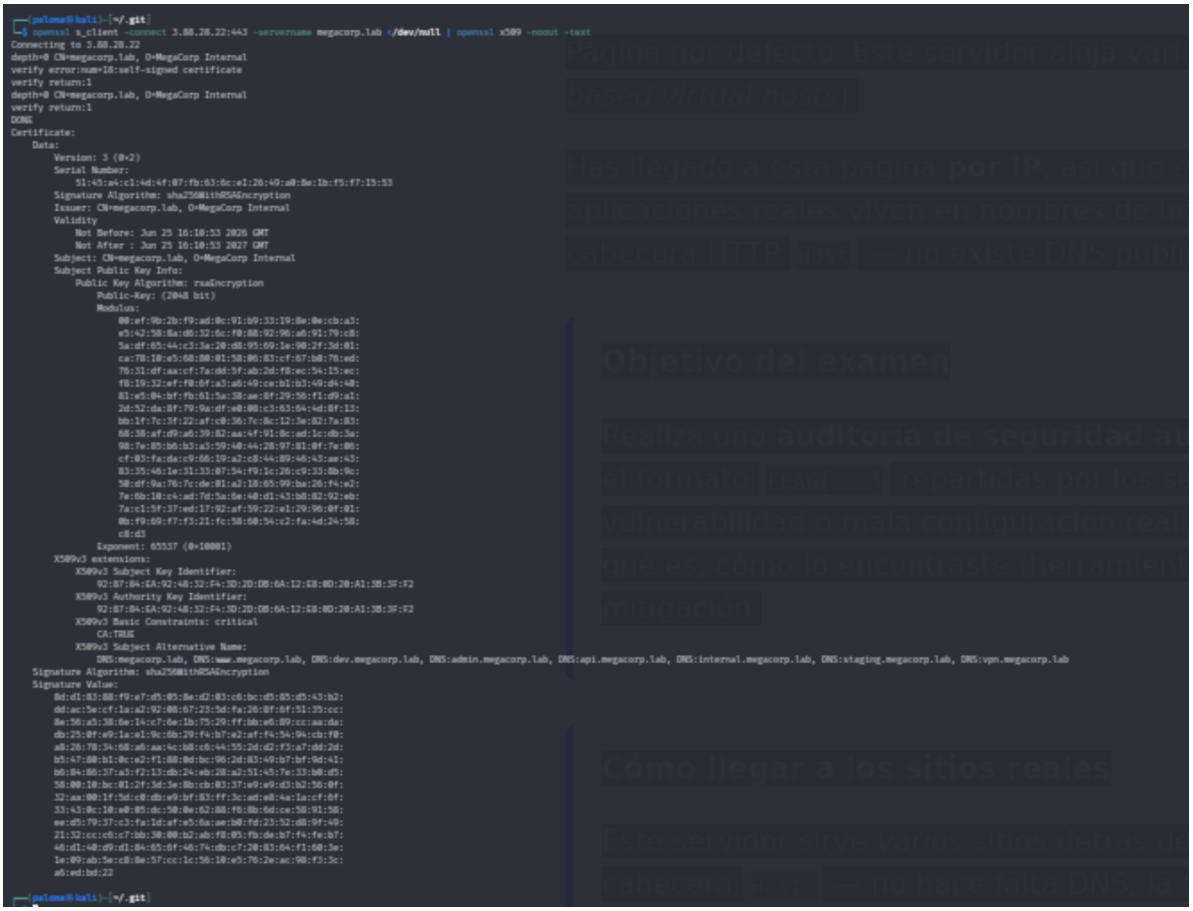
```
curl -k -H "Host: internal.megacorp.lab" https://3.88.28.22
```

Полученный ответ:

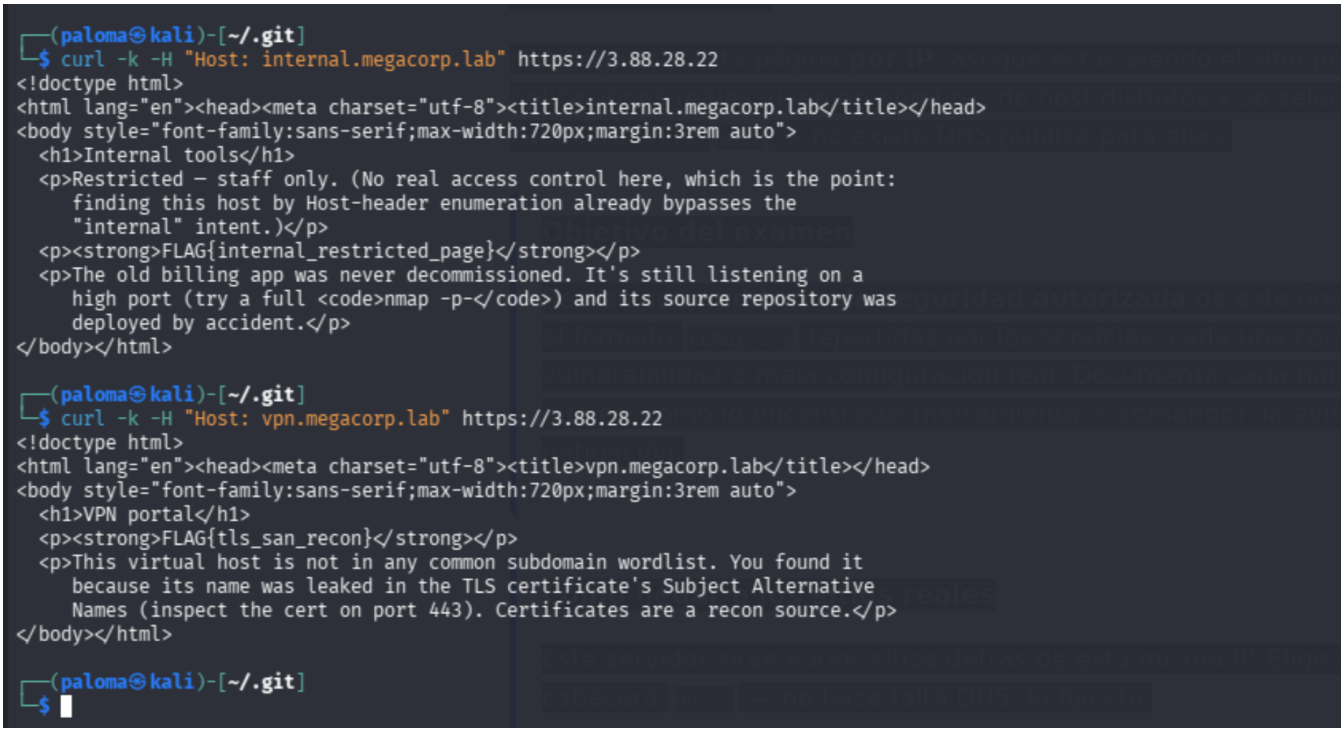
```
Restricted - staff only.
(No real access control here...)
FLAG{internal_restricted_page}
```

Перевод: «Доступ ограничен - только для сотрудников. (Реального контроля доступа здесь нет...)». `FLAG{internal_restricted_page}`.

СТРАНИЦА ОРИГИНАЛА 36 / 47



Перевод полей и сообщений на снимке сертификата: подключение к `3.88.28.22`; глубина 0, `CN=megacorp.lab`, `O=MegaCorp Internal`; ошибка проверки № 18 - самоподписанный сертификат; возвращаемое значение проверки 1; выполнено. Сертификат, данные: версия 3 (`0x2`), серийный номер, алгоритм подписи `sha256WithRSAEncryption`, издатель, срок действия, субъект, информация об открытом ключе субъекта. Начало действия: 25 июня 2026 года, 16:10:53 GMT; окончание: 25 июня 2027 года, 16:10:53 GMT. Алгоритм открытого ключа `rsaEncryption`, размер 2048 бит; модуль; экспонента 65537 (`0x10001`). Расширения X509v3: идентификатор ключа субъекта, идентификатор ключа центра сертификации, основные ограничения (критическое расширение), `CA:TRUE`; альтернативное имя субъекта с DNS-именами, перечисленными на странице оригинала 34. Далее указаны алгоритм и значение подписи. Серийный номер, шестнадцатеричные значения ключа и подписи сохранены на исходном снимке.



Перевод текста ответов на снимке

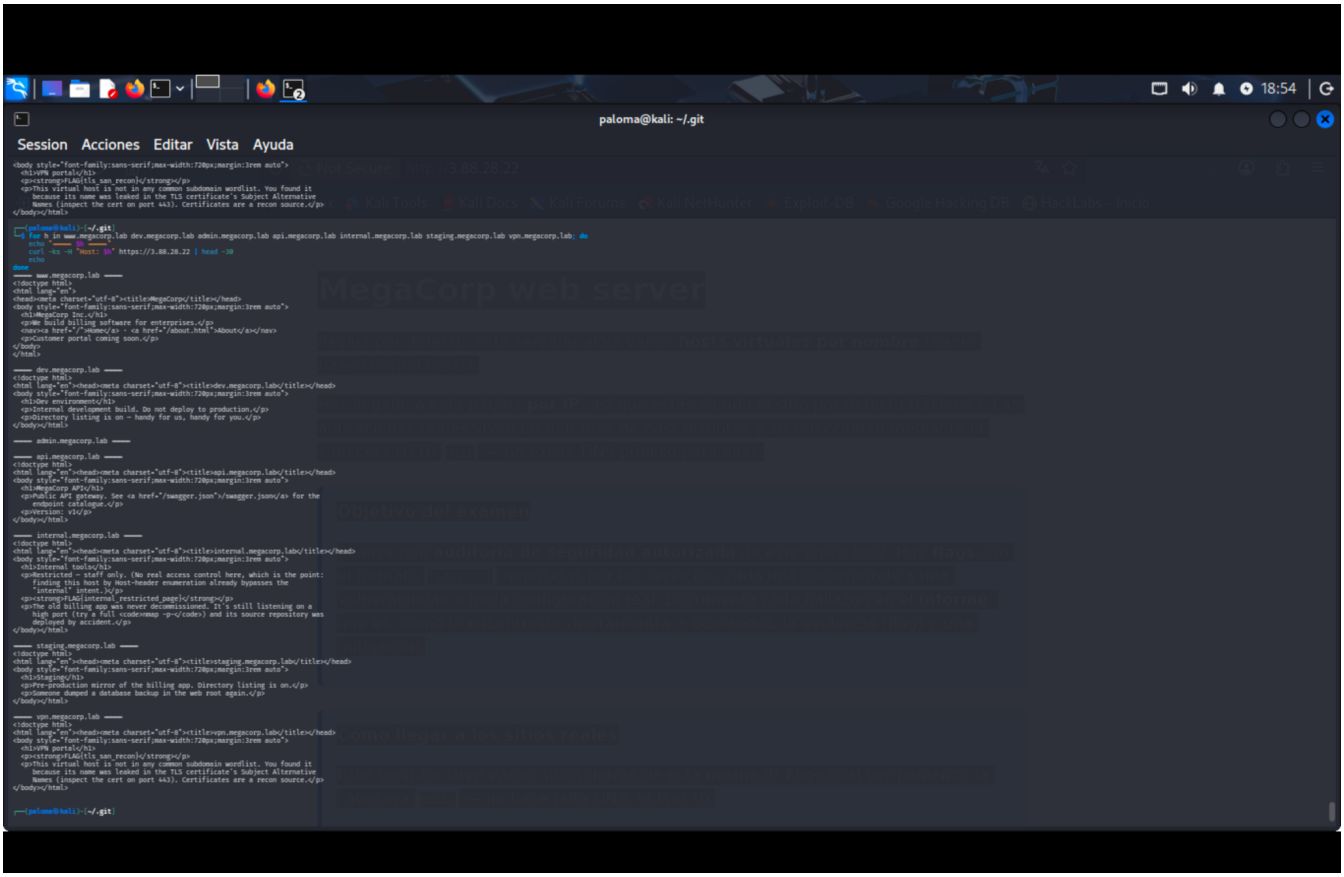
Внутренние инструменты (`internal.megacorp.lab`):

Доступ ограничен - только для сотрудников. Реального контроля доступа здесь нет; в этом и суть: обнаружение этого хоста путем перечисления заголовка Host уже обходит его предполагаемую «внутреннюю» закрытость.
`FLAG{internal_restricted_page}`
Старое приложение выставления счетов так и не было выведено из эксплуатации. Оно все еще слушает высокий порт (попробуйте полное сканирование `nmap -p-`), а его репозиторий исходного кода был развернут случайно.

Портал VPN (`vpn.megacorp.lab`):

`FLAG{tls_san_recon}`
Этого виртуального хоста нет ни в одном распространенном словаре поддоменов. Вы нашли его, потому что его имя утекло через Subject Alternative Names сертификата TLS (исследуйте сертификат на порту 443). Сертификаты - источник информации для разведки.

СТРАНИЦА ОРИГИНАЛА 37 / 47



Перевод дополнительного текста на снимке

- `www.megacorp.lab`: «MegaCorp Inc. Мы создаем программное обеспечение для выставления счетов предприятиям». Ссылки «Главная» и «О компании». «Клиентский портал появится скоро».
- `dev.megacorp.lab`: «Среда разработки. Внутренняя сборка для разработки. Не развертывать в производственной среде. Просмотр содержимого каталогов включен - удобно и нам, и вам».
- `admin.megacorp.lab`: в показанном выводе содержимого нет.
- `api.megacorp.lab`: «API MegaCorp. Публичный шлюз API. Каталог конечных точек см. в `/swagger.json`. Версия: v1».
- `internal.megacorp.lab`: ответ полностью переведен на странице оригинала 36.
- `staging.megacorp.lab`: «Предпроизводственная среда. Предпроизводственная копия приложения выставления счетов. Просмотр содержимого каталогов включен. Кто-то снова оставил резервную копию базы данных в корневом веб-каталоге».
- `vpn.megacorp.lab`: ответ полностью переведен на странице оригинала 36; в верхней части снимка повторяется окончание того же ответа.

Рисунок 14. Исследование сертификата TLS сервера.

На этом снимке показан анализ цифрового сертификата с помощью OpenSSL. Видно, что сертификат самоподписанный (self-signed certificate) и дополнительно раскрывает внутреннюю информацию организации: доменное имя `megacorp.lab` и поддомены в расширении Subject Alternative Name (SAN), включая `dev.megacorp.lab`, `admin.megacorp.lab`, `internal.megacorp.lab`, `staging.megacorp.lab` и `vpn.megacorp.lab`. Эти сведения позволили выявить виртуальные хосты, использованные затем на этапе разведки.

Рисунок 15. Перечисление виртуальных хостов с помощью заголовка Host.

На изображении показано выполнение скрипта, отправляющего HTTP-запросы с измененным заголовком `Host` для каждого имени, полученного из сертификата TLS. В ответ сервер возвращает различное содержимое для разных виртуальных хостов, что подтверждает наличие нескольких веб-сайтов на одном IP-адресе. При этом перечислении найдены хосты `internal.megacorp.lab` и `vpn.megacorp.lab`, содержащие конфиденциальную информацию и два флага упражнения.

Рисунок 16. Доступ к обнаруженным внутренним хостам.

Снимок показывает отдельные обращения к `internal.megacorp.lab` и `vpn.megacorp.lab` с помощью `curl` и изменения заголовка `Host`. На `internal.megacorp.lab` получен `FLAG{internal_restricted_page}`, а также информация о старом приложении выставления счетов, которое все еще работает на высоком порту, и о случайном развертывании репозитория его исходного кода. На `vpn.megacorp.lab` получен `FLAG{tls_san_recon}`, что подтверждает обнаружение хоста благодаря

информации, раскрытой в сертификате TLS. Это демонстрирует риск разглашения внутренних имен в цифровых сертификатах.

Страница также раскрывала дополнительную информацию об инфраструктуре: старое приложение выставления счетов все еще работает на высоком порту, а репозиторий исходного кода был развернут случайно.

Воздействие

- Несанкционированный доступ к ресурсам, предназначенным для внутреннего использования.
- Разглашение конфиденциальной информации об инфраструктуре организации.
- Облегчение разведки и планирования последующих атак благодаря раскрытию внутренних сервисов и небезопасных настроек.

Серьезность

Высокая.

Рекомендации

- Внедрить механизмы аутентификации и авторизации во всех внутренних сервисах.
- Ограничить доступ с помощью сегментации сети, списков контроля доступа (ACL) или межсетевого экрана.
- Не полагаться только на заголовок `Host` для защиты внутренних ресурсов.
- Регулярно пересматривать опубликованные виртуальные хосты, чтобы гарантировать недоступность внутренних сред извне.

Находка F-10 - Открытый репозиторий Git приложения Legacy Billing

Описание

При анализе HTTP-сервиса на порту 8000 выявлено приложение под названием Legacy Billing App. Само приложение сообщало, что оно развернуто непосредственно из рабочего каталога Git. При обращении к каталогу `/.git/` установлено, что репозиторий полностью доступен извне, что позволяет просматривать его структуру и потенциально восстанавливать исходный код приложения.

Доказательства

Использованные команды:

```
curl http://3.88.28.22:8000
curl http://3.88.28.22:8000/.git/
curl http://3.88.28.22:8000/.git/HEAD
curl http://3.88.28.22:8000/.git/config
```

Получен список содержимого каталога `.git`, включая следующие элементы:

```
HEAD
config
objects/
refs/
logs/
index
```

Кроме того, файл `HEAD` возвращал:

```
ref: refs/heads/master
```

Это подтверждало, что речь идет о работоспособном репозитории Git.

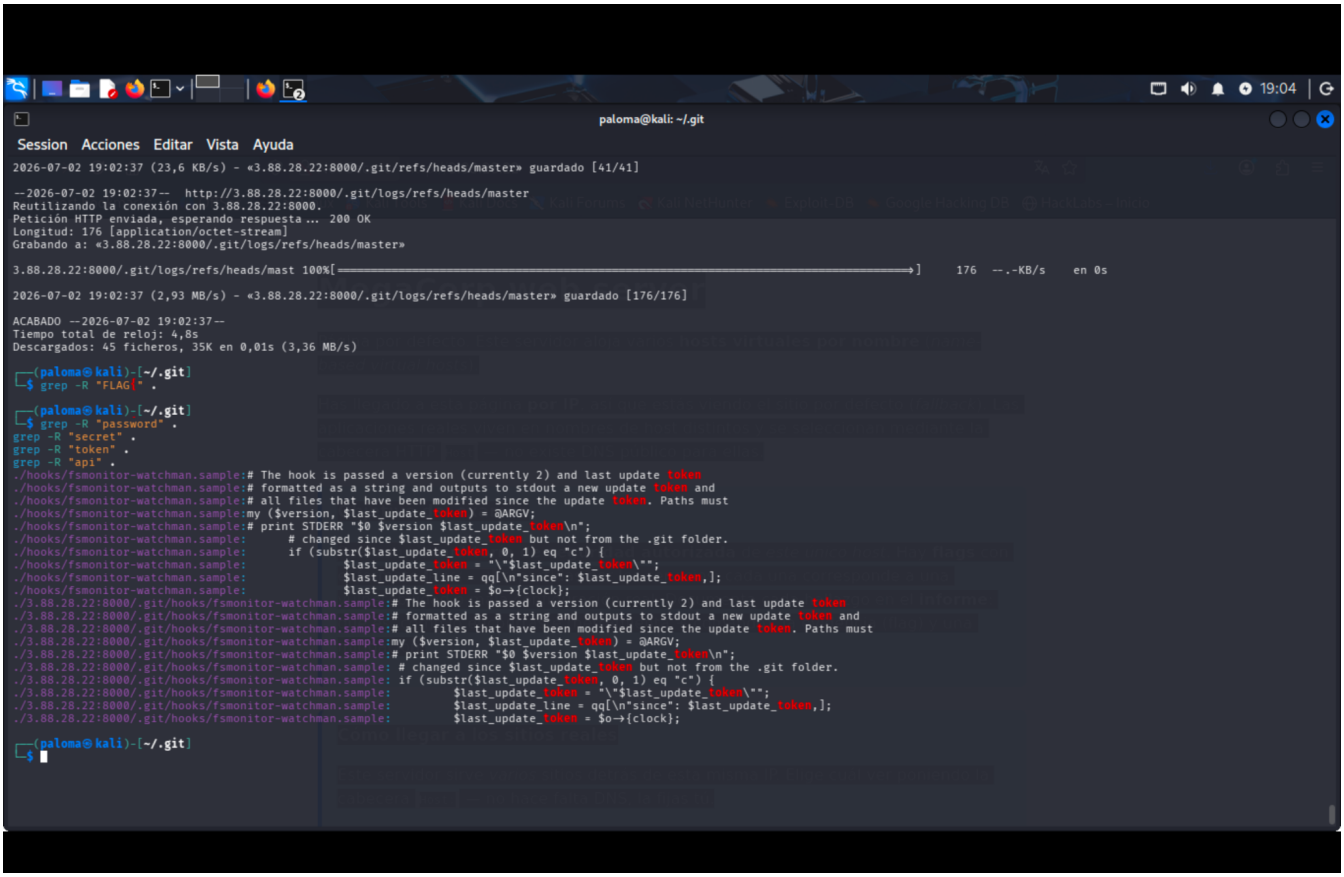
Воздействие

- Раскрытие исходного кода приложения.
- Возможное разглашение учетных данных, ключей API или конфиденциальной информации.
- Облегчение анализа уязвимостей и разработки целевых атак.

Серьезность

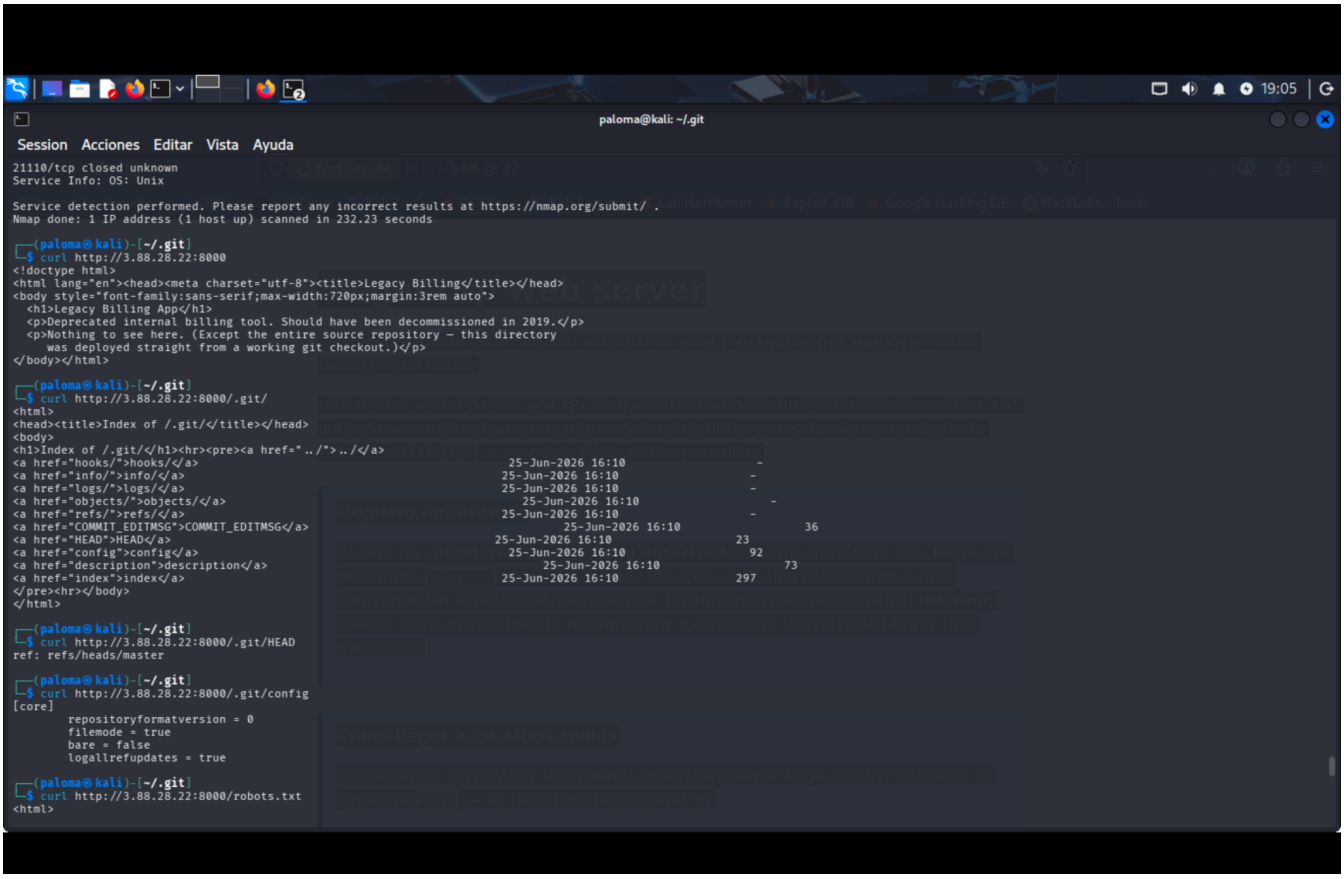
Высокая.

СТРАНИЦА ОРИГИНАЛА 40 / 47



Перевод сообщений на первом снимке: файл `3.88.28.22:8000/.git/refs/heads/master` сохранен, 41/41 байт, скорость 23,6 КБ/с; `2026-07-02 19:02:37`. Повторно используется соединение с `3.88.28.22:8000`. HTTP-запрос отправлен, ожидание ответа; `200 OK`. Длина: 176, тип `application/octet-stream`. Сохранение в `3.88.28.22:8000/.git/logs/refs/heads/master`; 100%, 176 байт, 0 секунд. Файл сохранен, 176/176 байт, скорость 2,93 МБ/с. Завершено `2026-07-02 19:02:37`; общее время 4,8 с; скачано 45 файлов, 35 КБ за 0,01 с, скорость 3,36 МБ/с.

Далее показан поиск строк `FLAG{`, `password`, `secret`, `token`, `api`. Найденные комментарии в двух копиях `fsmonitor-watchman.sample`: «В хук передаются версия (сейчас 2) и токен последнего обновления, представленный строкой; в стандартный вывод он возвращает новый токен обновления и все файлы, измененные после предыдущего токена обновления. Пути должны...»; «измененные после `$last_update_token`, но не из каталога `.git`». Программный код примера хука сохранен на снимке без перевода.

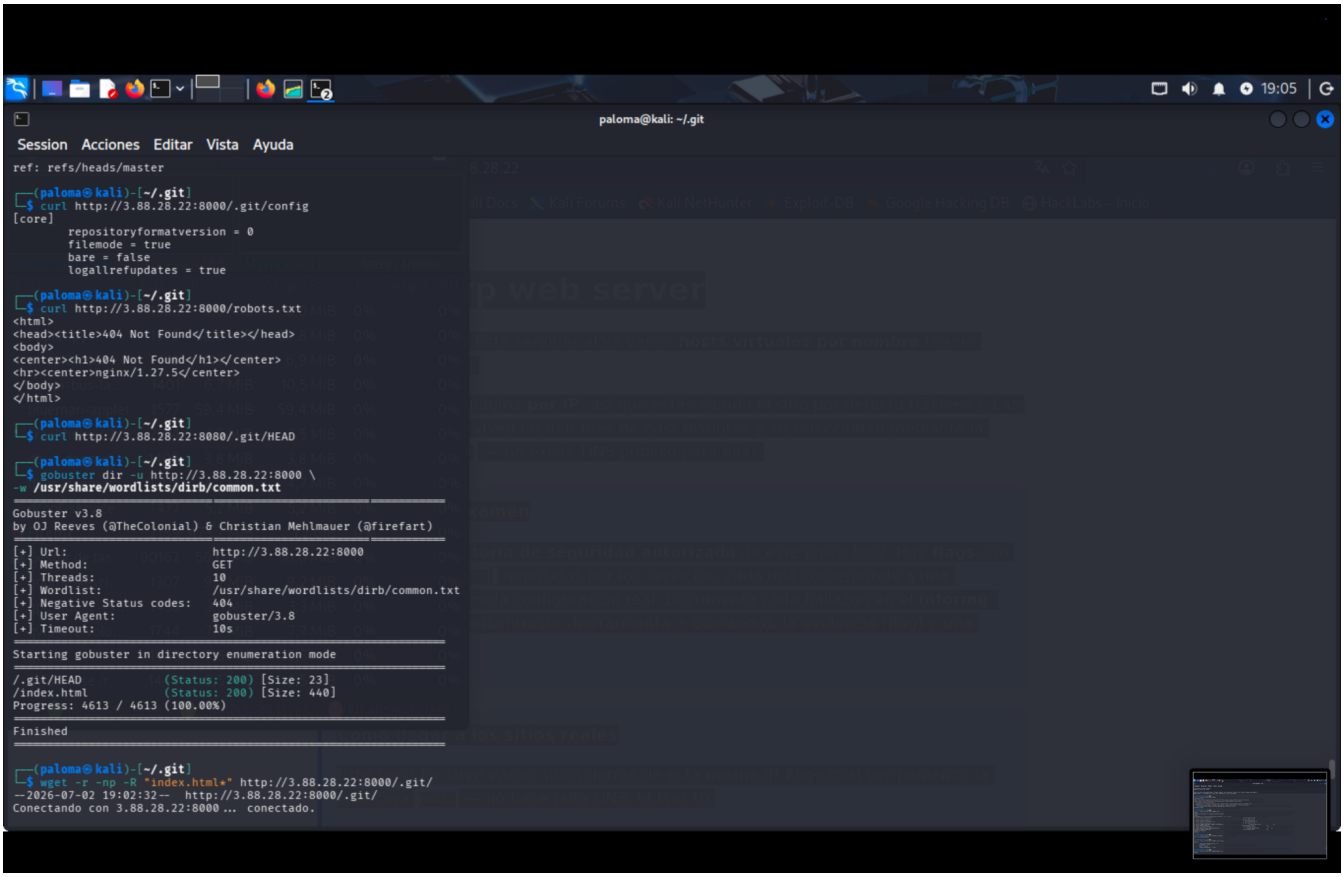


Перевод сообщений на втором снимке: порт `21110/tcp` закрыт, сервис неизвестен; информация о сервисах: ОС Unix. Определение сервисов выполнено; о неверных результатах предлагается сообщить на `https://nmap.org/submit/`. Nmap завершен: просканирован 1 IP-адрес, 1 доступный хост; 232,23 секунды.

Устаревшее приложение выставления счетов (Legacy Billing App): «Устаревший внутренний инструмент выставления счетов. Его следовало вывести из эксплуатации в 2019 году. Смотреть здесь не на что. Кроме всего репозитория исходного кода: этот каталог был развернут непосредственно из рабочей копии Git».

«Содержимое /.git/»: показаны каталоги `hooks/`, `info/`, `logs/`, `objects/`, `refs/` и файлы `COMMIT_EDITMSG`, `HEAD`, `config`, `description`, `index`; дата 25 июня 2026 года, 16:10. Размеры файлов соответственно 36, 23, 92, 73 и 297 байт. `HEAD` указывает на `refs/heads/master`. В конфигурации `[core]`: версия формата репозитория 0; учет режима файлов включен; репозиторий не является bare; журналирование всех обновлений ссылок включено. Затем показано начало ответа на запрос `robots.txt`.

СТРАНИЦА ОРИГИНАЛА 41 / 47



Перевод дополнительных сообщений на снимке: повторяются ссылка `HEAD` и конфигурация Git. Запрос `robots.txt` возвращает `404 Not Found` - «404: не найдено»; сервер nginx/1.27.5. Затем выполняется проверка `.git/HEAD` на порту 8080 и запускается Gobuster v3.8, авторы OJ Reeves (`@TheColonial`) и Christian Mehlmauer (`@firefart`). URL: `http://3.88.28.22:8000`; метод GET; 10 потоков; словарь `/usr/share/wordlists/dirb/common.txt`; исключаемый код ответа 404; User-Agent `gobuster/3.8`; время ожидания 10 с. Запуск в режиме перечисления каталогов. Результаты: `/.git/HEAD`, статус 200, размер 23; `/index.html`, статус 200, размер 440. Выполнено 4613/4613, 100%; завершено. Wget: `2026-07-02 19:02:32`, обращение к `http://3.88.28.22:8000/.git/`; подключение к `3.88.28.22:8000` установлено.

Рекомендации

- Удалить каталог `.git` из производственных сред.
- Настроить веб-сервер так, чтобы запретить доступ к скрытым файлам и каталогам.
- Проверять, что развертываемые приложения не содержат репозиториев системы контроля версий.

F-11 - Открытая панель мониторинга без аутентификации

Описание

При полном сканировании портов с помощью Nmap обнаружен доступный HTTP-сервис на порту 8080. При обращении к нему установлено, что это внутренняя панель мониторинга MegaCorp Monitoring, опубликованная в общем доступе и не защищенная никаким механизмом аутентификации. Кроме того, сам сервис сообщал о включенном просмотре содержимого каталогов, что усиливает раскрытие конфиденциальной информации.

СТРАНИЦА ОРИГИНАЛА 42 / 47

Доказательства

Использованный инструмент:

```
nmap -Pn -p- -sV 3.88.28.22
```

Обнаружен следующий сервис:

```
8080/tcp open http Caddy httpd
```

Перевод: порт `8080/tcp` открыт, сервис HTTP, Caddy httpd.

Затем к сервису обратились с помощью:

```
curl http://3.88.28.22:8080
```

Получен следующий ответ:

```
MegaCorp Monitoring
Internal monitoring dashboard, exposed on a non-standard port (8080) with no authentication.
FLAG{exposed_monitoring_8080}
Directory listing is enabled - see /status.txt
```

Перевод:

> Мониторинг MegaCorp. Внутренняя панель мониторинга открыта на нестандартном порту 8080 без аутентификации. `FLAG{exposed_monitoring_8080}`. Просмотр содержимого каталогов включен - см. `/status.txt`.

Воздействие

- Несанкционированный доступ к внутренней панели мониторинга.
- Раскрытие эксплуатационной информации об инфраструктуре.
- Увеличение поверхности атаки из-за публикации административных сервисов, доступных из Интернета.
- Возможность получения атакующим дополнительной информации благодаря просмотру содержимого каталогов.

Серьезность

Высокая.

СТРАНИЦА ОРИГИНАЛА 43 / 47

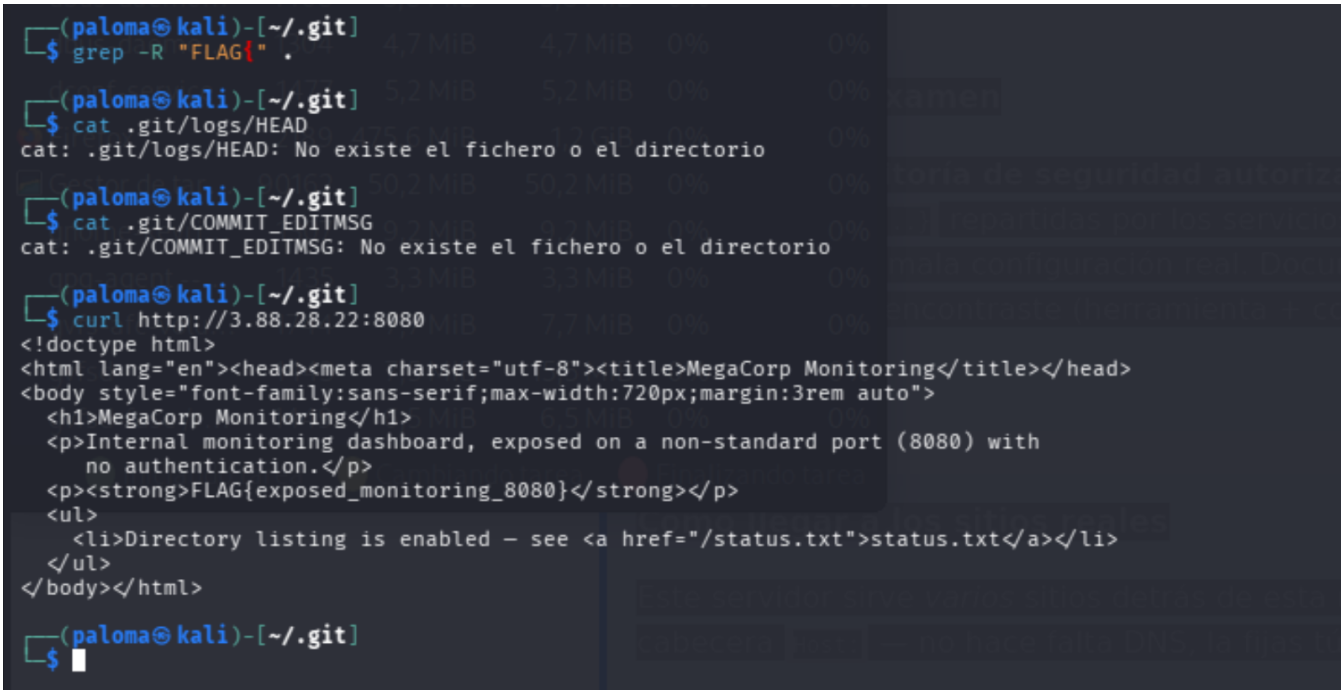


Рисунок 18. Обнаружение открытой панели мониторинга на порту 8080.

На изображении показан доступ к HTTP-сервису, выявленному при полном сканировании портов с помощью Nmap. При подключении к порту 8080 с использованием `curl` установлено, что сервер размещает внутреннюю панель мониторинга MegaCorp Monitoring, публично доступную без аутентификации. Ответ сервера содержал `FLAG{exposed_monitoring_8080}`, подтверждающий уязвимость, и сообщал о включенном просмотре содержимого каталогов со ссылкой на ресурс `/status.txt`. Это указывает на небезопасную конфигурацию, которая может облегчить раскрытие конфиденциальной информации об инфраструктуре и увеличить поверхность атаки системы.

Перевод дополнительных сообщений на снимке: `cat` для `.git/logs/HEAD` и `.git/COMMIT_EDITMSG` сообщает «Нет такого файла или каталога». Текст ответа панели мониторинга полностью переведен на странице оригинала 42. Команды и HTML-разметка сохранены в исходном снимке.

Рекомендации

- Ограничить доступ к панели мониторинга с помощью надежной аутентификации.
- Ограничить доступ к сервису с помощью межсетевого экрана, VPN или списков контроля доступа (ACL).
- Отключить просмотр содержимого каталогов на веб-сервере.
- Не открывать внутренние сервисы на публично доступных портах и регулярно проводить аудиты для обнаружения подобных небезопасных настроек.

6. ЦЕПОЧКА АТАКИ (ОПИСАНИЕ)

Аудит начался с этапа разведки, в ходе которого были выявлены несколько виртуальных хостов и получена значимая информация из сертификата TLS (F-01, F-02 и F-08). Сведения в Subject Alternative Names (SAN - альтернативных именах субъекта) позволили обнаружить новые внутренние домены, первоначально не видимые.

Затем изменение заголовка `Host` позволило получить доступ к внутренним виртуальным хостам (F-09), извлечь конфиденциальную информацию об инфраструктуре и обнаружить существование устаревшего приложения выставления счетов и случайно развернутого репозитория Git.

Далее полное сканирование портов позволило выявить дополнительные сервисы, включая приложение Legacy Billing с открытым каталогом `.git` (F-10) и внутреннюю панель мониторинга на порту 8080, доступную без аутентификации (F-11).

Совокупность этих находок позволила постепенно расширить знания об инфраструктуре, найти внутренние ресурсы и продемонстрировать, что несколько критически важных сервисов доступны из Интернета из-за небезопасной конфигурации и отсутствия надлежащих мер по усилению защиты.

Краткая цепочка атаки:

F-01 → F-02 → F-08 → F-09 → F-10 → F-11 → получение конфиденциальной информации, доступ к внутренним ресурсам и расширение поверхности атаки за счет многочисленных ошибок конфигурации.

7. ВЫВОДЫ И РЕКОМЕНДАЦИИ

Общее состояние безопасности

Проверенная инфраструктура характеризуется недостаточным уровнем безопасности из-за накопившихся ошибок конфигурации и раскрытия конфиденциальной информации. Выявлены многочисленные уязвимости, позволившие обнаружить внутренние виртуальные хосты, получить доступ к ресурсам ограниченного доступа, раскрыть репозитории Git, получить информацию об

инфраструктуре через сертификаты TLS и получить доступ к административным сервисам без аутентификации. Совокупность этих находок значительно облегчает разведку и увеличивает поверхность атаки системы.

Типичные общие первопричины

- Раскрытие конфиденциальной информации на этапе разведки.
- Небезопасная конфигурация веб-серверов.
- Открытость репозиториев Git и внутренних файлов.
- Отсутствие мер по усилению защиты опубликованных сервисов.
- Отсутствие механизмов аутентификации во внутренних сервисах.
- Раскрытие каталогов и ресурсов через просмотр содержимого каталогов.
- Разглашение информации об инфраструктуре через сертификаты TLS.

Приоритетный план устранения

Приоритет	Действие	Устраняемые находки	Трудозатраты
1	Удалить все репозитории `.git` и любые конфиденциальные файлы из производственных сред.	F-03, F-10	Низкие
2	Ограничить доступ к виртуальным хостам и внутренним сервисам с помощью аутентификации, межсетевого экрана или VPN.	F-09, F-11	Средние
3	Отключить просмотр содержимого каталогов и защитить ресурсы, опубликованные на веб-серверах.	F-06, F-10, F-11	Низкие
4	Пересмотреть конфигурацию TLS: удалить внутренние имена из сертификатов и использовать сертификаты, выданные доверенным CA.	F-08	Низкие

СТРАНИЦА ОРИГИНАЛА 46 / 47

Приоритет	Действие	Устраняемые находки	Трудозатраты
5	Применить меры по усилению защиты ко всем открытым сервисам, удалить устаревшие приложения и сократить поверхность атаки.	F-01, F-02, F-07, F-10, F-11	Средние
6	Внедрить процедуру проверки безопасности перед развертыванием и регулярно проводить аудит конфигурации и открытости сервисов.	Все находки (F-01 - F-11)	Средние

8. ПРИЛОЖЕНИЯ

На этапе разведки и перечисления ресурсов использовались стандартные инструменты аудита безопасности и словари, включенные в Kali Linux по умолчанию.

Использованные инструменты

- Nmap - сканирование портов и обнаружение сервисов.
- cURL - HTTP-запросы и изменение заголовка `Host`.
- OpenSSL - исследование сертификата TLS.
- Gobuster - перечисление каталогов и веб-ресурсов.
- Git - анализ открытого репозитория.
- Wget - скачивание ресурсов с сервера.

Использованные словари

- `/usr/share/wordlists/dirb/common.txt`

Этот словарь использовался с Gobuster для выявления доступных каталогов и ресурсов в открытых HTTP-сервисах.

Собственные скрипты

Для автоматизации перечисления виртуальных хостов, полученных из сертификата TLS, использовался небольшой скрипт Bash:

СТРАНИЦА ОРИГИНАЛА 47 / 47

```
for h in www.megacorp.lab dev.megacorp.lab admin.megacorp.lab api.megacorp.lab internal.megacorp.lab
staging.megacorp.lab vpn.megacorp.lab; do
    echo "===== $h ====="
    curl -ks -H "Host: $h" https://3.88.28.22 | head -30
    echo
done
```

Этот скрипт позволил определить различные виртуальные хосты, опубликованные на сервере, обнаружить внутренние ресурсы и найти несколько флагов упражнения.